



**NATIONAL CRITICAL INFORMATION INFRASTRUCTURE (NCII)
SECURITY ASSESSMENT, THREAT ANALYSIS,
AND DATA PROTECTION COMPLIANCE REVIEW**

GROUP B – CENTRAL & MIDDLE BELT REGION

Assigned States:

*Niger, Kebbi, Kaduna, Plateau, Nasarawa,
Benue, Kogi, Kwara, and Taraba*

Assigned Sectors:

*E-Commerce, Aviation, Hospitality, Gaming,
Education, Healthcare, and Insurance*

Prepared For

CYBERGON Cybersecurity Training

Prepared By

NetworkShield Security Team

TEAM MEMBERS

Miracle Godwin Ogbo

Jessy Bievenue

Emmanuel Olofu

Course

Ethical Hacking Professional Course

Submitted To

CYBERGON Cybersecurity Training

Date

June 2026

DECLARATION

I hereby declare that this project report titled
“National Critical Information Infrastructure (NCII)
Security Assessment, Threat Analysis, and Data Protection
Compliance Review” was conducted as part of the
Ethical Hacking Professional Course requirements under
CYBERGON Cybersecurity Training.

The assessment was performed using publicly available
information, passive reconnaissance techniques, security
analysis methodologies, threat intelligence resources,
and industry-standard cybersecurity frameworks.

No unauthorized access, exploitation, disruption,
or modification of any organization's systems was
performed during this assessment.

Table of Content

Contents

1.0 EXECUTIVE SUMMARY	4
2.0 PROJECT OVERVIEW	5
2.1 Project Objectives	5
2.2 Assessment Scope	6
2.3 Assessment Methodology & Tools Used	6
3.0 PROJECT OBJECTIVES	8
4.0 ASSESSMENT METHODOLOGY	9
5.0 FRAMEWORKS AND STANDARDS USED	11
6.0 NIGER STATE ASSESSMENT	12
6.1 SECTOR: EDUCATION - Niger State, Nigeria	12
6.2 SECTOR – HEALTHCARE – Niger State, Nigeria	22
6.3 SECTOR – HOSPITALITY – Niger State, Nigeria	35
7.0 BENUE STATE ASSESSMENT	40
7.1 SECTOR: EDUCATION - Benue State, Nigeria	40
7.2 SECTOR: HEALTHCARE - Benue State, Nigeria	52
8.0 KOGI STATE ASSESSMENT	66
8.1 SECTOR – E-COMMERCE – Kogi State, Nigeria	66
9.0 KWARA STATE ASSESSMENT	75
9.1 SECTOR – GAMING – Kwara State, Nigeria	75
9.2 SECTOR: INSURANCE - Kwara State, Nigeria	85
10. NASARAWA STATE ASSESSMENT	102
10.1 SECTOR: E-commerce - Nasarawa State, Nigeria	102
11. PLATEAU STATE ASSESSMENT	117
11.1 SECTOR – AVIATION – Plateau State, Nigeria	117
12. KADUNA STATE ASSESSMENT	131
12.1 SECTOR – INSURANCE – Kaduna State, Nigeria	131
13. KEBBI STATE ASSESSMENT	138
13.1 SECTOR – EDUCATION – Kebbi State, Nigeria	138
13.2 SECTOR – HEALTHCARE – Kebbi State, Nigeria	154
14. TARABA STATE ASSESSMENT	169
14.1 SECTOR – EDUCATION – Taraba State, Nigeria	169

1.0 EXECUTIVE SUMMARY

This project is a cybersecurity assessment of important organizations in Nigeria under the CYBERGON Ethical Hacking Course.

We focused on organizations in the **Central and Middle Belt region**, covering 7 important sectors: E-commerce, Aviation, Hospitality, Gaming, Education, Healthcare, and Insurance across 9 states.

The main goal was to:

- Identify publicly visible digital systems (websites, domains, servers)
- Analyze possible security weaknesses
- Understand how attackers could target them
- Map findings to known security standards like:
 - OWASP Top 10
 - CVE (known vulnerabilities)
 - CWE (weakness types)
 - CVSS (risk severity scoring)
 - EPSS (likelihood of exploitation)

No hacking or exploitation was performed. Only **legal OSINT (public information analysis)** was used.

Key Findings

We discovered common risks across organizations such as:

- Exposed online services (attack surface is large)
- Weak or multiple login pages
- Heavy use of third-party tools (Google, Facebook, analytics scripts)
- Possible outdated software in some cases
- Risk of data exposure if security is not properly managed

Conclusion

Most organizations are not “hacked”, but they are:

exposed due to structure, complexity, and internet visibility

So attackers don't need to break systems, they can target weak entry points like:

- login pages
- APIs
- third-party scripts

2.0 PROJECT OVERVIEW

National Critical Information Infrastructure (NCII) comprises systems, networks, services, and digital assets that are essential to the security, economic stability, public health, and overall functioning of a nation. The compromise, disruption, or destruction of these critical assets can have significant consequences on government operations, businesses, and citizens.

As organizations increasingly rely on digital technologies and internet-connected systems, they become more exposed to cyber threats such as unauthorized access, ransomware attacks, data breaches, denial-of-service attacks, insider threats, and social engineering attacks. These threats can result in operational disruptions, financial losses, regulatory penalties, and reputational damage.

To support the protection of critical infrastructure and sensitive information assets, this project was conducted as part of the Ethical Hacking Professional Course under CYBERGON Cybersecurity Training. The assessment focuses on selected organizations operating within critical sectors across the Central and Middle Belt region of Nigeria.

The project evaluates organizations within the E-Commerce, Aviation, Hospitality, Gaming, Education, Healthcare, and Insurance sectors across Niger, Kebbi, Kaduna, Plateau, Nasarawa, Benue, Kogi, Kwara, and Taraba States. These sectors play vital roles in economic development, public service delivery, transportation, education, healthcare provision, financial protection, and digital commerce.

The assessment aims to identify potential cybersecurity risks, analyze publicly accessible attack surfaces, review potential vulnerabilities, evaluate possible threat scenarios, and assess organizational preparedness against modern cyber threats. Additionally, the project considers compliance requirements under the Nigeria Data Protection Act (NDPA) and aligns findings with internationally recognized cybersecurity frameworks and standards.

The findings and recommendations presented in this report are intended to assist organizations in strengthening their cybersecurity posture, reducing risk exposure, improving data protection practices, and enhancing resilience against emerging cyber threats.

2.1 Project Objectives

The objectives of this assessment are to:

1. Identify organizations operating within selected critical sectors across the assigned states.
2. Conduct reconnaissance and open-source intelligence (OSINT) gathering on publicly accessible organizational assets.
3. Analyze exposed attack surfaces and publicly available technologies.
4. Identify potential vulnerabilities and security weaknesses using recognized industry frameworks.
5. Map identified weaknesses to applicable CVE, CWE, OWASP, CVSS, and EPSS references where appropriate.
6. Evaluate the potential impact and exploitability of identified risks.
7. Assess organizational cybersecurity readiness in relation to the Nigeria Data Protection Act (NDPA).
8. Provide actionable remediation recommendations to improve cybersecurity resilience.
9. Promote awareness of cybersecurity best practices within critical sectors.

2.2 Assessment Scope

This assessment covers selected organizations operating within the following sectors:

- 9 states in Central & Middle Belt Nigeria
- 7 sectors including insurance, e-commerce, healthcare, etc.

We only used:

- public websites
- search engines
- WHOIS data
- DNS analysis tools

The assessment focuses on publicly accessible information, digital footprints, internet-facing services, technology identification, threat analysis, and cybersecurity risk evaluation.

The review was conducted using passive reconnaissance techniques and publicly available information sources.

Out of Scope

The following activities were not performed:

- Unauthorized system access
- Active exploitation of vulnerabilities
- Password attacks
- Denial-of-Service (DoS) testing
- Social engineering attacks
- Malware deployment
- Data modification or destruction

No intrusive testing was conducted during this assessment.

2.3 Assessment Methodology & Tools Used

This assessment was conducted using a **passive Open-Source Intelligence (OSINT) methodology** focused on identifying publicly observable digital assets, technologies, and potential security weaknesses across selected organizations in Niger State, Nigeria.

No intrusive testing, vulnerability scanning, exploitation attempts, or unauthorized access activities were performed. All findings were derived strictly from publicly available information.

The assessment followed industry-aligned security frameworks including OWASP Top 10, OWASP API Security Top 10, CWE, CVE, and NIST cybersecurity principles for classification and risk interpretation.

TOOLS USED:

- Google dorking - to find hidden pages and files
- WHOIS - to check domain ownership
- DNS tools - to see server structure
- BuiltWith - to detect website technology
- Netcraft - to analyze hosting and infrastructure

3.0 PROJECT OBJECTIVES

The primary objective of this assessment is to conduct a structured cybersecurity risk analysis of selected organizations operating within critical sectors across the Central and Middle Belt region of Nigeria.

The specific objectives of this project are to:

1. Identify and document organizations operating within the assigned sectors across Niger, Kebbi, Kaduna, Plateau, Nasarawa, Benue, Kogi, Kwara, and Taraba States.
2. Perform Open-Source Intelligence (OSINT) gathering to determine the digital footprint and publicly exposed assets of selected organizations.
3. Analyze attack surfaces including domains, subdomains, IP infrastructure, and internet-facing services.
4. Identify potential security weaknesses and misconfigurations based on publicly available information and security intelligence sources.
5. Map identified weaknesses to industry-standard vulnerability frameworks such as CVE, CWE, OWASP Top 10, CVSS, and EPSS.
6. Assess potential threat scenarios and evaluate the exploitability and impact of identified risks.
7. Evaluate organizational cybersecurity posture in relation to the Nigeria Data Protection Act (NDPA) requirements and compliance expectations.
8. Provide remediation strategies including immediate and long-term security improvements aligned with industry best practices.
9. Promote awareness of cybersecurity risks affecting critical infrastructure sectors within Nigeria.

This assessment is intended to demonstrate practical application of cybersecurity principles including threat modeling, risk analysis, and security framework alignment in a real-world context.

4.0 ASSESSMENT METHODOLOGY

The assessment methodology adopted in this project is based on a structured cybersecurity risk evaluation approach combining Open-Source Intelligence (OSINT), passive reconnaissance techniques, and industry standard security frameworks.

The methodology was designed to ensure that all findings were derived from publicly available information without the use of intrusive, destructive, or unauthorized testing techniques.

4.1 Open-Source Intelligence (OSINT) Collection

OSINT techniques were used to gather publicly available information about each organization. This included analysis of search engine data, official websites, domain information, public records, and technology footprint identification.

4.2 Attack Surface Mapping

Each organization's digital presence was analyzed to identify potential attack surfaces. This included examination of:

- Domain infrastructure and subdomains
- Public IP address exposure
- Web applications and portals
- Email and DNS configurations
- Publicly exposed services and endpoints

4.3 Technology Identification

Technology stack identification was performed using publicly available fingerprinting techniques to determine frameworks, web servers, content management systems, and backend technologies in use.

4.4 Vulnerability Intelligence Mapping

Identified technologies and configurations were mapped against known vulnerability databases such as:

- Common Vulnerabilities and Exposures (CVE)
- Common Weakness Enumeration (CWE)
- OWASP Top 10 Security Risks

This allowed for the identification of potential security weaknesses associated with observed technologies and configurations.

4.5 Risk and Impact Assessment

Security risks were evaluated using industry-standard scoring models including:

- Common Vulnerability Scoring System (CVSS)
- Exploit Prediction Scoring System (EPSS)

Each identified weakness was assessed based on likelihood of exploitation and potential business impact.

4.6 Threat Modeling

Threat scenarios were developed to simulate possible attack paths that malicious actors could use to exploit identified weaknesses. These scenarios considered confidentiality, integrity, and availability (CIA) impacts.

4.7 Compliance Evaluation

The assessment also considered data protection and regulatory compliance requirements based on the Nigeria Data Protection Act (NDPA) and general cybersecurity governance principles aligned with the NIST Cybersecurity Framework.

4.8 Limitations

This assessment was limited to publicly available information and did not involve active penetration testing, exploitation of vulnerabilities, or unauthorized access to any system or network.

5.0 FRAMEWORKS AND STANDARDS USED

This assessment is guided by internationally recognized cybersecurity frameworks and standards to ensure structured analysis, consistency, and alignment with industry best practices.

1. NIST Cybersecurity Framework (CSF)

The NIST CSF provides a structured approach to managing cybersecurity risks through five core functions: Identify, Protect, Detect, Respond, and Recover. It was used to guide risk identification and security posture evaluation across organizations.

2. Common Vulnerabilities and Exposures (CVE)

CVE is a standardized database of publicly known cybersecurity vulnerabilities. It was used to reference known software vulnerabilities associated with observed technologies and systems.

3. Common Weakness Enumeration (CWE)

CWE categorizes software and system weaknesses. It was used to classify identified security flaws such as improper authentication, misconfiguration, and insecure design.

4. OWASP Top 10

The OWASP Top 10 represents the most critical web application security risks. It was used to evaluate potential vulnerabilities in publicly accessible web applications and portals.

5. Common Vulnerability Scoring System (CVSS)

CVSS provides a standardized method for rating the severity of vulnerabilities. It was used to assess the impact and severity of identified security weaknesses.

6. Exploit Prediction Scoring System (EPSS)

EPSS estimates the likelihood of a vulnerability being exploited in the wild. It was used to prioritize risk severity and real-world threat potential.

7. Nigeria Data Protection Act (NDPA)

The NDPA provides legal requirements for protecting personal data in Nigeria. It was used to evaluate compliance risks related to data handling, storage, and protection practices.

8. OWASP Top 10 (2025)

The OWASP Top 10 (2025) represents the latest globally recognized framework for identifying the most critical web application security risks. It was used to evaluate and classify vulnerabilities observed in publicly accessible web applications, APIs, and digital portals.

This includes risks such as authentication failures, insecure design, access control issues, and security misconfigurations.

9. Vulnerability Intelligence Platforms (Vulners.com)

Vulners.com is a cybersecurity vulnerability intelligence platform used to cross-reference, analyze, and validate known vulnerabilities and exploit data from multiple security sources. It supports correlation of CVEs, security advisories, and real-world exploit availability.

6.0 NIGER STATE ASSESSMENT

6.1 SECTOR: EDUCATION - Niger State, Nigeria

Organization Name:

Federal University of Technology, Minna (FUTMINNA)

Domain Name:

futminna.edu.ng

1. Organization Profile & Reconnaissance (OSINT) - FUTMinna

Target Identification

Federal University of Technology, Minna (FUTMINNA) is a public higher education institution in Niger State, Nigeria. The university provides digital academic services to students and staff through multiple online platforms.

Digital Footprint

The organization operates several internet-facing systems including:

- Main institutional website (futminna.edu.ng)
- Student portal (eportal.futminna.edu.ng)
- Admission and registration systems
- Results checking and academic services
- Library and research repositories
- Multiple subdomains (alumni, irepo, codel, futec, library services)

Hosting & Infrastructure

- Public IP address: 49.50.80.17
- Hosting environment: Linux (Ubuntu-based infrastructure)
- Web services: Apache HTTP Server
- CMS platform: WordPress-based academic web systems
- Backend stack: PHP + MySQL

Attack Surface Mapping

The following exposed components increase the attack surface:

- Student and staff login portals
- Admission and registration systems

- Public academic documents (PDFs, notices, policies)
- Multiple interconnected subdomains
- WordPress-based websites with plugins and themes
- Publicly exposed web server and CMS versions

Key Observation

The presence of multiple authentication portals and academic systems significantly increases exposure to phishing, credential attacks, and automated exploitation attempts.

2. Vulnerability & Weakness Analysis - FUTMinna

Framework Reference

Vulnerabilities and weaknesses identified during this assessment were analyzed and mapped using internationally recognized cybersecurity frameworks and standards, including:

- Common Vulnerabilities and Exposures (CVE)
- Common Weakness Enumeration (CWE)
- OWASP Top 10:2025
- National Vulnerability Database (NVD)
- Common Vulnerability Scoring System (CVSS)

Technical Flaws Identified

Outdated Web Server Software

The university uses an Apache HTTP Server version that is no longer fully secure in modern environments.

- Apache HTTP Server: 2.4.41
- WordPress CMS: 6.1.9
- Elementor plugin and additional WordPress extensions detected

Security Concern

Both Apache and WordPress versions are publicly detectable through fingerprinting, allowing attackers to match them with known vulnerabilities.

Framework Mapping (Security Classification)

Apache HTTP Server Weakness

The Apache web server is running version **2.4.41**, which is outdated and associated with multiple publicly documented security issues.

CVE Mapping

- **CVE-2020-1934** – Memory handling issue in mod_proxy_ftp that may lead to exposure of uninitialized memory
- **CVE-2020-1927** – Redirect manipulation via encoded newline injection in mod_rewrite
- **CVE-2020-13950** – Denial of Service caused by malformed HTTP request headers

CWE Mapping

- CWE-908 - Use of Uninitialized Resource
- CWE-601 - URL Redirection to Untrusted Site ('Open Redirect')
- CWE-476 - NULL Pointer

OWASP Top 10 (2025) Mapping

- **A02: Security Misconfiguration** – outdated and improperly maintained server configuration
- **A08: Software and Data Integrity Failures** – reliance on outdated server components
- **A06: Insecure Design** – use of Apache 2.4.41 with known CVEs

Security Impact Summary (Apache)

- Attackers can exploit known CVEs to disrupt services
- HTTP request manipulation may allow abnormal server behavior
- Outdated modules increase risk of denial-of-service attacks
- Version exposure allows direct vulnerability targeting

WordPress CMS Weakness

The WordPress environment includes plugin-level risks that introduce additional vulnerabilities.

- **CVE-related issues include:**
 - **CVE-2024-12504** - Stored Cross-Site Scripting (XSS) via vulnerable plugins

- **CVE-2024-0789** - IP spoofing through weak validation mechanisms
- **CWE Mapping:**
 - **CWE-79** - Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
 - **CWE-348** - Use of Less Trusted Source
- **OWASP Top 10 2025 Mapping:**
 - A05: Injection
 - A07: Authentication Failures
 - A03: Software Supply Chain Risks

Operational & Human Weaknesses

- Large student population increases phishing success probability
- Multiple login portals increase credential reuse risk
- Public academic documents may leak metadata useful to attackers
- Distributed subdomains make monitoring and patching inconsistent
- Heavy reliance on third-party WordPress plugins increases dependency risk

3. Threat Impact & Exploitability Scenario - FUT Minna

Primary Risk

Publicly Accessible Authentication Systems and Outdated Web Technologies (Apache & WordPress) and Third-Party Plugin Exposure plus Technology Fingerprinting

Attack Scenario

Phase 1: Reconnaissance (MITRE ATT&CK – TA0043)

An external attacker performs passive reconnaissance against FUTMINNA using publicly available sources.

Activities may include:

- Google dorking of the domain and subdomains
- Collection of publicly exposed student/staff portals
- Identification of login and admission systems
- Technology fingerprinting (Apache, WordPress, PHP versions)
- Enumeration of academic services and document repositories

Information discovered:

- Student portal (eportal.futminna.edu.ng)
- Admission and registration systems
- Library and academic repositories
- Apache HTTP Server 2.4.41
- WordPress CMS 6.1.9
- Elementor and third-party plugins
- Public academic documents (PDFs, notices)

Phase 2: Resource Development (MITRE ATT&CK – TA0042)

The attacker builds infrastructure to target FUTMINNA users.

Potential actions:

- Creation of look-alike university domains
- Development of phishing login pages (student portal imitation)
- Preparation of malicious WordPress exploit scripts (based on known CVEs)
- Design of fake admission/result notification emails
- Hosting credential harvesting infrastructure

Because no strong domain/email protection controls are assumed at reconnaissance level, spoofed communications may appear legitimate to users.

Phase 3: Initial Access (MITRE ATT&CK – TA0001)

The attacker delivers phishing or exploit-based attacks to users.

Example lures:

- Admission acceptance notifications
- Result checking alerts
- Portal password reset emails
- Academic registration reminders
- Staff administrative notices

Victims may:

- Enter credentials into fake login pages
- Click malicious links leading to compromised web pages
- Interact with infected WordPress-based content

Phase 4: Credential Access (MITRE ATT&CK – TA0006)

If successful, attackers obtain valid credentials.

Potential methods:

- Credential harvesting via phishing pages
- Password reuse exploitation (credential stuffing)
- Brute-force attacks against exposed login portals
- Exploitation of weak authentication controls

Public-facing portals increase the probability of successful credential compromise.

Phase 5: Account Access and Abuse (MITRE ATT&CK – TA0003)

Compromised credentials are used to access internal systems.

Potential targets:

- Student portal accounts
- Admission processing systems
- Result management systems
- Administrative dashboards

The attacker's access level depends on user privilege (student, staff, admin).

Phase 6: Impact (MITRE ATT&CK – TA0040)

Successful compromise may result in:

- Unauthorized access to academic records
- Manipulation of student or admission data
- Service disruption of portals
- Data leakage of academic information
- Reputation damage to the institution

No direct evidence of exploitation was observed during this assessment.

CVSS (Scenario-Based Assessment)

Overall Estimated Score

CVSS v3.1: **5.8 – 6.5 (Medium)**

Justification

- Exploitation requires external interaction or credential compromise
- Multiple public-facing portals increase attack surface
- Known vulnerabilities exist in Apache and WordPress ecosystem
- Version exposure enables targeted exploitation
- User interaction required for phishing-based attacks

EPSS (Exploit Prediction Scoring System)

Estimated Likelihood

Medium–High

Factors Influencing Likelihood

- Publicly exposed student and staff portals
- Known vulnerable software versions (Apache 2.4.41, WordPress 6.1.9)
- Large user base (students and staff)
- High phishing success rate in education sector
- Availability of public exploit knowledge for CVEs

Business Impact Assessment

Operational Impact

- Disruption of student registration and result systems
- Downtime of admission and academic services
- Delays in examination and administrative processing

Financial Impact

- Incident response and system recovery costs
- Infrastructure upgrade and patching expenses
- Cost of forensic investigation and external auditing

Reputational Impact

- Loss of trust in university digital systems
- Negative perception among students and staff
- Reduced confidence in online academic services

Regulatory Impact

Potential implications under:

- Nigeria Data Protection Act (NDPA)
- Institutional data governance policies
- Academic records protection requirements

Threat Impact Summary

The assessment identified a realistic attack path where an adversary could combine publicly available reconnaissance data, outdated web technologies (Apache and WordPress), and exposed authentication portals to conduct phishing and credential-based attacks against FUTMINNA. While no evidence of active exploitation was identified, the combination of outdated software, third-party plugin dependencies, and large-scale user exposure significantly increases the institution's attack surface and susceptibility to targeted cyber threats.

4. Mitigation & Technical Remediation Plan - FUTMinna

Immediate Mitigation (Short-Term)

- Restrict or limit public access to sensitive authentication portals (student, admission, and administrative systems) where possible.
- Enable Web Application Firewall (WAF) protection to filter malicious traffic and block common exploit attempts.
- Implement login rate limiting and account lockout mechanisms to reduce brute-force and credential stuffing attacks.
- Disable unnecessary Apache modules (especially those not required for production environments).
- Hide or minimize version disclosure in HTTP headers (Apache, PHP, WordPress) to reduce fingerprinting risk.
- Monitor server logs continuously for abnormal login attempts, scanning activity, or exploit patterns.
- Temporarily restrict or secure high-risk subdomains if vulnerabilities are detected.
- Enforce HTTPS across all web services to protect data in transit.

Permanent Remediation (Long-Term)

Infrastructure Security

- Upgrade Apache HTTP Server from version 2.4.41 to the latest stable and supported release.
- Upgrade WordPress CMS from version 6.1.9 to the latest secure version.
- Update and patch all WordPress plugins (including Elementor and third-party extensions).

- Establish a formal patch management policy for all web-facing systems.
- Maintain an up-to-date inventory of all servers, subdomains, and applications.
- Remove unused services, deprecated modules, and inactive web applications.

Web Application Security

- Enforce secure coding practices for all web applications (input validation and output sanitization).
- Remove vulnerable or unnecessary WordPress plugins and themes.
- Disable debugging and development features in production environments.
- Apply secure configuration hardening for Apache, PHP, and WordPress environments.
- Conduct regular security code reviews for custom-built academic applications.

Authentication & Access Control

- Enforce Multi-Factor Authentication (MFA) for staff and administrative accounts.
- Implement Role-Based Access Control (RBAC) across all university systems.
- Reduce exposure of multiple login endpoints where possible.
- Apply account lockout policies after repeated failed login attempts.
- Enforce strong password policies and periodic credential updates.

Security Monitoring & Incident Response

- Deploy centralized logging and Security Information and Event Management (SIEM) system.
- Enable real-time alerts for suspicious authentication and scanning activity.
- Perform continuous vulnerability scanning of all public-facing systems.
- Conduct regular penetration testing to identify new attack paths.
- Establish an incident response plan for phishing, credential theft, and web exploitation scenarios.
- Monitor external exposure (OSINT monitoring) to detect new attack surface changes.

Verification Strategy

To confirm that vulnerabilities have been properly remediated, the following steps should be performed:

- Re-scan all domains and subdomains to confirm Apache and WordPress upgrades.
- Validate removal of known CVE exposure using vulnerability scanning tools (NVD-based checks).

- Confirm that login protections (MFA, rate limiting, logout policies) are functioning correctly.
- Verify HTTP headers to ensure server version disclosure is minimized or removed.
- Test WAF effectiveness using simulated attack payloads.
- Perform OSINT re-assessment (Google dorking and fingerprinting) to ensure reduced exposure.
- Review system logs to confirm reduction in malicious or automated scanning activity.
- Conduct periodic penetration testing to ensure long-term security posture stability.

Final Summary

The remediation strategy for FUTMINNA focuses on reducing exposure from outdated web technologies, strengthening authentication security, minimizing public attack surface, and improving continuous monitoring. Implementing these controls will significantly reduce the risk of exploitation through phishing, credential attacks, and known vulnerabilities affecting Apache and WordPress ecosystems.

6.2 SECTOR – HEALTHCARE – Niger State, Nigeria

Organization Name:

Top medical Centre

Domain Name:

Topmedicalcentremx.com

1. Organization Profile & Reconnaissance (OSINT) – Top medical Centre

Target Identification

Top Medical Centre is a private healthcare facility located in Minna, Niger State, Nigeria. The organization provides medical services including General Medicine, Surgery, Pediatrics, Obstetrics and Gynecology, Family Medicine, Urology, Neurosurgery, Laboratory Services, Diagnostic Services, Ambulance Services, and Emergency Care.

The primary digital asset identified during this assessment is:

- Location: Minna, Niger State, Nigeria
- Physical Address: No. 13 Top Medical Road, Tunga, Minna, Niger State
- Public Contact Email: info@topmedicalcentremx.com
- Public Contact Numbers:
 - 07081319997
 - 08034535544
 - 08138178088

The website serves as the organization's primary online platform for healthcare information, patient communication, and appointment scheduling.

Organization Overview

Information gathered from the organization's website indicates that Top Medical Centre operates as a 24-hour healthcare facility serving patients within Minna and surrounding communities.

The hospital offers various healthcare services including:

- General Medicine
- General Surgery
- Pediatrics
- Obstetrics and Gynecology
- Family Medicine
- Urology

- Neurosurgery
- Diagnostic Services
- Laboratory Services
- Ambulance and Emergency Services

The website also provides an online appointment booking feature that allows patients to schedule visits electronically.

Digital Footprint Discovery

Open-Source Intelligence (OSINT) activities were performed using Google Dorking, WHOIS, BuiltWith, WhatCMS, and Netcraft.

The reconnaissance process identified:

Publicly Accessible Pages

- Homepage
- About Page
- Services Page
- FAQs Page
- Founder Information Page
- Awards Gallery

Search Engine Exposure

Google indexing confirms that the website's primary pages are publicly accessible and searchable.

Search queries revealed information relating to:

- Medical services
- Emergency healthcare services
- Contact information
- Appointment booking functionality
- Hospital background information

No publicly exposed PDF documents were identified during reconnaissance.

No publicly accessible login portal or administrative dashboard was discovered through search engine enumeration.

Technology Identification

Domain and Infrastructure

- Domain: topmedicalcentremx.com

- Registration Date: January 2026
- DNS Provider: Cloudflare DNS
- DNSSEC: Enabled

Hosting Information

- Hosting Provider: Cloudflare
- Content Delivery Network (CDN): Cloudflare
- Additional CDN Services: Google Cloud CDN
- Observed IP Address: 162.159.140.166

Website Technologies

- Node.js
- Nuxt.js Framework
- Vue.js
- JavaScript
- AJAX
- HTML5
- CSS3

Security Technologies

- Cloudflare Protection Services
- Cloudflare Bot Manager
- SPF Email Protection
- HTTPS Redirection
- DNSSEC Enabled

Third-Party Services

- Zoho Mail
- Google Maps
- Google Fonts
- PayPal Integration
- Cloudflare Analytics

The identified technology stack indicates the use of modern web technologies and cloud-based infrastructure.

Attack Surface Mapping

Attack surface mapping was conducted to identify assets that are exposed to the public internet and could potentially be targeted by threat actors.

Public Website

The organization's primary web presence is publicly accessible through:

- topmedicalcentremx.com

The website contains information about hospital operations, services, contact information, and patient support resources.

Appointment Booking System

An online appointment booking form was identified on the website.

The form accepts user-supplied information including:

- First Name
- Last Name
- Phone Number
- Email Address
- Service Requested
- Appointment Date
- Preferred Appointment Time

Because the feature accepts user input, it represents an externally accessible component that should be securely managed and monitored.

Public Contact Channels

The website publicly exposes:

- Multiple telephone numbers
- Official email address
- Physical address

While necessary for communication, these channels may be targeted through phishing, spam campaigns, or social engineering attempts.

Email Infrastructure

The assessment identified:

- SPF Record Configured
- Zoho Mail Services

Email infrastructure represents a potential attack vector because healthcare organizations frequently exchange sensitive information with patients.

Third-Party Dependencies

The website relies on several third-party services:

- Cloudflare
- Google Services
- Zoho Mail
- PayPal

Any weakness affecting these integrations could indirectly affect the organization's online services.

Administrative Interfaces

No publicly accessible login pages, administrator portals, or exposed management interfaces were discovered during Google Dorking activities.

Summary

The primary attack surface identified during this assessment consists of the public website, appointment booking functionality, contact channels, email infrastructure, and third-party integrations. No direct exposure of patient records, confidential documents, or administrative systems was identified during the reconnaissance phase.

2. Vulnerability & Weakness Analysis - Top Medical Centre

Technical Flaws Identified

During the assessment of **Top Medical Centre (topmedicalcentremx.com)**, no direct critical vulnerability such as exposed admin panels, leaked documents, or publicly accessible patient records was discovered through passive reconnaissance. However, several weaknesses were identified that could increase the organization's security risk.

Finding 1: Missing Domain based Message Authentication, Reporting, and Conformance. (DMARC) Policy

Netcraft analysis showed that the domain does not have a configured DMARC record.

Risk:

Without DMARC enforcement, attackers may be able to send fraudulent emails pretending to originate from the hospital's domain. Such emails could be used for phishing, appointment scams, malware delivery, or social engineering attacks against patients and staff.

Framework Mapping

Category	Mapping
CWE	CWE-346: Origin Validation Error
OWASP Top 10-2025	A02 – Security Misconfiguration
CVE	Not Applicable

Finding 2: Exposure of Organizational Information Through OSINT

The public website exposes a significant amount of organizational information including:

- Hospital address
- Contact phone numbers
- Official email address
- Founder information
- Operational details
- Medical services offered

Risk:

Although much of this information is intended for public use, threat actors can leverage it during reconnaissance to craft targeted phishing emails, impersonation attacks, or social engineering campaigns.

Framework Mapping

Category	Mapping
CWE	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
OWASP Top 10-2025	A01 – Broken Access Control (Information Exposure)
CVE	Not Applicable

Finding 3: Newly Registered Domain

WHOIS information indicates that the domain was registered in January 2026.

Risk:

New domains generally have limited security maturity and may still be undergoing configuration and hardening processes. Security monitoring, email protection policies, backup strategies, and vulnerability management procedures may not yet be fully established.

Framework Mapping

Category	Mapping
CWE	CWE-16: Configuration
OWASP Top 10-2025	A02 – Security Misconfiguration
CVE	Not Applicable

Finding 4: Third-Party Dependency Exposure

Technology analysis identified dependence on several third-party services including:

- Cloudflare

- Google Cloud CDN
- Zoho Mail
- Google CDN

Risk:

A compromise, misconfiguration, or vulnerability affecting any third-party service could indirectly impact the hospital's online services.

Framework Mapping

Category	Mapping
CWE	CWE-1104: Use of Unmaintained Third-Party Components
OWASP Top 10-2021	A06– Vulnerable and Outdated Components
CVE	No specific CVE identified during assessment

Framework Mapping Summary

Finding	CWE	OWASP Top 10	CVE
Missing DMARC Record	CWE-346	A02 Security Misconfiguration	N/A
Information Exposure Through OSINT	CWE-200	A01 Broken Access Control	N/A
New Domain Security Maturity Risk	CWE-16	A02 Security Misconfiguration	N/A
Third-Party Dependency Risk	CWE-1104	A06 Vulnerable and Outdated Components	No CVE identified

Operational & Human Weaknesses

The assessment also identified several non-technical risks:

Social Engineering Exposure

The hospital publicly discloses:

- Staff and founder information
- Email addresses
- Phone numbers
- Physical location

An attacker could use this information to impersonate hospital management, IT personnel, vendors, or medical staff.

Security Awareness Risk

No publicly visible security awareness statements, privacy policy, or security reporting mechanism were identified during the assessment.

This may indicate limited public guidance regarding cybersecurity practices and incident reporting.

Reputation-Based Targeting Risk

As a healthcare organization that provides 24/7 medical services, the hospital may be an attractive target for:

- Ransomware operators
- Phishing campaigns
- Business Email Compromise (BEC) attacks
- Data theft attempts

Healthcare organizations are frequently targeted because service disruption can directly affect patient care, increasing pressure to restore operations quickly.

Conclusion

No critical vulnerability was directly confirmed during passive reconnaissance. However, the absence of DMARC protection, exposure of organizational information, reliance on third-party services, and potential social engineering risks collectively increase the attack surface of Top Medical Centre. These weaknesses could be leveraged by attackers to support phishing, impersonation, or other cyberattacks against the organization.

3. Threat Impact & Exploitability Scenario – Top Medical Centre

This section explains how the identified weaknesses in **Top Medical Centre (topmedicalcentremx.com)** could potentially be exploited, and the possible impact on the organization.

Primary Security Concern for Analysis

From Section 2, the most relevant security weakness for impact analysis is:

- **Missing DMARC email protection policy**

This is selected because it directly enables **email spoofing and phishing attacks**, which are common entry points for cyberattacks in healthcare environments.

CVSS Score (Estimated)

Since this is not a software bug but a configuration weakness, the CVSS score is estimated based on impact.

Metric	Value
Attack Vector	Network (Email-based)
Attack Complexity	Low
Privileges Required	None
User Interaction	Required
Scope	Unchanged
Confidentiality Impact	Medium
Integrity Impact	Medium
Availability Impact	Low

Estimated CVSS Score: 6.5 (Medium Severity)

Explanation:

The attacker does not need system access. Only the ability to send email is required, making exploitation relatively easy.

EPSS (Exploit Probability)

EPSS estimates the likelihood that a vulnerability will be exploited in real-world attacks.

For this case:

- **Estimated EPSS Range: 0.4 – 0.7 (Moderate Likelihood)**

Reason:

- Email spoofing is widely used in phishing campaigns
- Healthcare organizations are frequent targets
- No DMARC increases success rate of impersonation attacks

Attack Scenario (How an Attacker Would Exploit It)

An attacker could exploit the missing DMARC policy using the following steps:

Step 1: Reconnaissance

The attacker collects publicly available information:

- Hospital email addresses (e.g., info@topmedicalcentremx.com)
- Staff names and roles (from website content)
- Phone numbers and services offered

Step 2: Email Spoofing

The attacker sends emails that appear to come from the hospital domain:

Example:

billing@topmedicalcentremx.com

appointments@topmedicalcentremx.com

Because there is no DMARC policy, receiving mail servers may not properly reject the fake email.

Step 3: Social Engineering

The attacker sends messages such as:

- Fake appointment confirmations
- Fake lab result notifications
- Fake payment requests
- Malware attachments disguised as medical reports

Step 4: User Interaction

A patient or staff member may:

- Click a malicious link
- Download infected attachments
- Enter login credentials into a fake portal

Step 5: Impact Escalation

If successful, the attacker can:

- Steal patient or staff credentials
- Gain access to internal systems
- Launch ransomware attacks
- Conduct Business Email Compromise (BEC)

Business Impact Analysis

If the above attack succeeds, the potential impact includes:

1. Operational Impact

- Disruption of hospital services
- Delay in patient care
- Interruption of emergency services

2. Financial Impact

- Recovery costs from cyber incident
- Possible ransom payments (if ransomware is deployed)
- Legal and compliance penalties

3. Reputational Impact

- Loss of patient trust
- Negative public perception
- Reduced patient visits

4. Data Security Impact

- Exposure of sensitive patient data
- Possible violation of privacy regulations
- Unauthorized access to medical records

Summary of Threat Level

Factor	Assessment
Likelihood	Medium
Impact	High
Overall Risk	Medium–High

Conclusion

While no direct system vulnerability was found, the absence of DMARC significantly increases the success rate of phishing and impersonation attacks. In a healthcare environment like Top Medical Centre, this can lead to serious operational disruption, data exposure, and reputational damage if exploited.

4. Mitigation & Technical Remediation Plan-Top medical Centre

Immediate Mitigation (Short-term)

These are quick actions that can reduce exposure risk without major system redesign:

- **Implement DMARC Policy**
 - Configure DMARC with at least p=quarantine or p=reject
 - This reduces email spoofing and phishing risk targeting the hospital domain
- **Enforce Email Authentication Controls**
 - Ensure SPF and DKIM records are properly configured and aligned

- This strengthens email verification for outbound messages
- **Secure Appointment Form Input**
 - Add server-side input validation for all form fields
 - Sanitize user input to prevent malicious script injection
 - Restrict unexpected characters in form submissions
- **Enable Basic Security Headers**
 - Add headers such as:
 - Content-Security-Policy (CSP)
 - X-Frame-Options
 - X-Content-Type-Options
 - This reduces risk of XSS and clickjacking attacks
- **Limit Form Abuse**
 - Apply rate limiting or CAPTCHA on appointment/contact forms
 - Prevent automated spam or bot submissions

Permanent Remediation (Long-term)

These actions improve long-term security posture:

- **Adopt Secure Development Practices**
 - Follow OWASP secure coding guidelines during website updates
 - Ensure validation and sanitization are applied at both client and server levels
- **Regular Security Updates**
 - Keep frontend frameworks (Vue/Nuxt and dependencies) updated
 - Patch third-party libraries regularly to reduce supply-chain risk
- **Deploy Web Application Firewall (WAF)**
 - Use Cloudflare WAF rules to detect and block:
 - SQL injection attempts
 - Cross-site scripting payloads
 - Bot-based attacks
- **Email Security Hardening**
 - Move DMARC policy from monitoring (none) to enforcement (quarantine or reject)
 - Continuously monitor DMARC reports for spoofing attempts
- **Access Control Improvements**

- Ensure any admin or backend systems are not publicly exposed
- Implement strong authentication mechanisms (MFA recommended)

Verification Strategy

To confirm that vulnerabilities have been properly mitigated:

- **DMARC Verification**
 - Use DNS lookup tools to confirm DMARC record is active and enforced
 - Test spoofed email attempts to ensure rejection or quarantine
- **Web Application Testing**
 - Re-test appointment form with controlled input payloads
 - Confirm scripts or malicious inputs are not executed or stored
- **Security Header Validation**
 - Use security header scanning tools to confirm CSP, X-Frame-Options, etc.
- **WAF Testing**
 - Attempt basic injection payloads and confirm blocking via Cloudflare logs
- **Ongoing Monitoring**
 - Enable logging for form submissions and email authentication reports

Summary

The main security improvements for Top Medical Centre focus on strengthening email authentication (DMARC), securing user input on web forms, and improving overall web application security through headers, WAF protection, and secure coding practices. These measures collectively reduce phishing risk, injection risk, and misuse of the hospital's digital platform.

6.3 SECTOR – HOSPITALITY – Niger State, Nigeria

Organization Name:

Guddel Hotel

Domain Name:

guddelhotel.com

1. Organization Profile & Reconnaissance (OSINT) – Guddel Hotel

Organization Overview

GUDDDEL HOTEL is a hospitality service provider located in Minna, Niger State, Nigeria. The hotel offers accommodation services, room reservations, guest management, dining facilities, and customer support through its online platform.

The website serves as the primary digital presence for promoting hotel services, displaying room offerings, providing contact information, and facilitating booking activities.

Target Identification

Item	Details
Organization Name	GUDDDEL HOTEL
Sector	Hospitality
Location	Minna, Niger State, Nigeria
Domain	guddelhotel.com
IP Address	216.198.79.1
Hosting Provider	Vercel Inc.
Registrar	NameCheap Inc.
Domain Creation Date	2 February 2026

The organization operates a public-facing hospitality website used for hotel information, bookings, and customer engagement.

Digital Footprint

The hotel's digital presence includes:

- Primary website: **guddelhotel.com**
- Public booking and room information pages
- Contact pages with phone and email details

- Location and hotel service descriptions

Infrastructure is hosted on **Vercel (cloud-based hosting platform)** with DNS managed via NameCheap.

Attack Surface Mapping

During Dorking, the following exposed services and public-facing components were identified:

- Hotel booking and reservation system
- Room listing and pricing pages
- Contact forms (email and phone exposure)
- Location and map integration services
- Customer review/public information pages
- Web application frontend built on React

Observation:

No administrative login portals or backend management interfaces were publicly indexed or exposed.

2. Vulnerability & Weakness Analysis – Guddel Hotel

Technical Flaws

No outdated software versions or legacy infrastructure were directly identified. However, the following security-related weaknesses were observed:

1. Missing DMARC Record

- The domain does not implement DMARC protection.
- SPF is present but not enforced with DMARC policy.

Security Weakness:

- Increased susceptibility to email spoofing and phishing impersonation.

Framework Mapping

Standard	Mapping
CWE	CWE-290: Authentication Bypass by Spoofing
OWASP Top 10	A01: Broken Access Control / A07: Identification and Authentication Failures
CVE	Not applicable (no specific vulnerability identified in software)

Operational & Human Weaknesses

- Publicly exposed email address and phone number increase exposure to phishing and social engineering attacks.
- Availability of hotel pricing, services, and contact details enables attackers to craft highly convincing fraudulent messages.
- Customer trust could be exploited for fake booking or payment scams.

3. Threat Impact & Exploitability Scenario – Guddel Hotel

CVSS Scoring (Estimated Risk Level)

Primary Issue: Missing DMARC Protection

Metric	Value
CVSS Score	6.5 (Medium)
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	Required
Impact	Medium (Confidentiality & Integrity)

EPSS Score (Likelihood of Exploit)

- **Estimated EPSS:** Moderate (0.4 – 0.6)
- Reason:
 - Hospitality sector is frequently targeted by phishing campaigns
 - Email spoofing is easy to automate without DMARC enforcement
 - Public trust in hotel communication increases success rate

Attack Vector Scenario

A malicious actor could exploit the missing DMARC record as follows:

1. Attacker configures a spoofed email using:
 - booking@guddelhotel.com
2. Sends fraudulent messages to customers:
 - Fake booking confirmations

- Fake payment requests
- 3. Customers receive email because DMARC enforcement is absent
- 4. Victims are redirected to phishing pages or scam payment portals
- 5. Credentials or payment information are stolen

Business Impact

Financial Impact

- Potential loss from fraudulent bookings or payments
- Customer refund liabilities due to scams
- Increased operational costs for incident response

Reputational Impact

- Loss of customer trust in official hotel communications
- Negative online reviews and public perception damage

Operational Impact

- Increased customer complaints and support workload
- Possible disruption of booking confidence and revenue flow

Regulatory Impact

- Possible violations of data protection and consumer protection expectations

4. Mitigation & Technical Remediation Plan – Guddel Hotel

Immediate Mitigation (Short-Term)

- Implement a basic DMARC policy:

v=DMARC1; p=quarantine;

- Monitor email traffic for spoofed messages
- Warn customers about official communication channels
- Strengthen SPF alignment validation

Permanent Remediation (Long-Term)

Email Security Hardening

- Upgrade DMARC policy to:

v=DMARC1; p=reject;

- Fully implement SPF + DKIM alignment

- Enforce strict domain validation for outgoing emails

Web Application Security Improvements

- Add security headers (CSP, HSTS, X-Frame-Options)
- Secure booking and contact forms against abuse
- Implement rate limiting on contact endpoints

Human & Operational Security

- Train staff on phishing and impersonation threats
- Educate customers on official communication channels
- Monitor domain abuse using external threat intelligence tools

Verification Strategy

- Confirm DMARC record using DNS lookup tools
- Test email spoofing attempts (should fail or be quarantined/rejected)
- Validate SPF and DKIM alignment
- Monitor email logs for unauthorized sending attempts
- Perform periodic penetration testing on email domain security

Conclusion

This assessment of GUDDER HOTEL identified a modern cloud-hosted web infrastructure supporting hospitality services such as bookings, room listings, and customer engagement. The platform has a relatively clean external attack surface with no exposed administrative interfaces or sensitive files discovered during reconnaissance.

However, the absence of a DMARC policy presents a notable email security weakness, increasing the risk of domain spoofing and phishing attacks targeting customers. Combined with publicly available contact and booking information, this creates opportunities for social engineering and fraudulent communications.

Overall, while the technical infrastructure appears well-structured, strengthening email security controls and improving awareness against phishing attacks will significantly enhance the organization's security posture.

7.0 BENUE STATE ASSESSMENT

7.1 SECTOR: EDUCATION - Benue State, Nigeria

Organization Overview

Organization Name: Rev. Fr. Moses Orshio Adasu University, Makurdi (MOAUM)

Former Name: Benue State University (BSU)

Website: bsum.edu.ng

Sector: Higher Education

Location: Makurdi, Benue State, Nigeria

Type: Public University

1. Organization Profile & Rconnaissance (OSINT) -BSUM

Organization Overview

Benue State University (recently referenced as **Rev. Fr. Moses Orshio Adasu University, Makurdi**) is a Nigerian tertiary education institution providing undergraduate, postgraduate, research, and administrative academic services. Its digital ecosystem supports admissions, student registration, academic publishing, library services, and departmental operations.

The institution operates multiple interconnected subdomains supporting different academic and administrative functions, making it a distributed education web infrastructure with multiple attack surfaces.

Target Identification

Item	Details
Organization Name	Benue State University (BSUM) / MOAUM Makurdi
Sector	Education (Public University)
Location	Makurdi, Benue State, Nigeria
Primary Domain	bsum.edu.ng
IP Address	69.89.12.167
Hosting Provider	eApps / Strategic Systems Consulting (AS209242)
Server OS	Ubuntu
Web Server	Apache 2.4.41
Backend Language	PHP
Nameservers	ns11–ns14.eapps.com

Item	Details
Domain Age	Created Dec 4, 2010
Registrar	layer3 / NIC Nigeria

Digital Footprint

Primary Web Assets

- <https://bsum.edu.ng> (main university site)
- <https://portal.bsum.edu.ng> (student portal / login systems)
- <https://remedial.bsum.edu.ng> (pre-science / remedial admissions portal)
- <https://library.bsum.edu.ng> (library system)
- <https://jupeb.bsum.edu.ng> (JUPEB admissions system)

Observed Functional Systems

- Student admission processing system
- Post-UTME verification system
- Academic journal publishing platform
- Staff management and ICT portals
- Library authentication system
- Alumni and departmental pages

Attack Surface Mapping

From OSINT and dorking results, exposed surface includes:

1. Authentication Systems

- Student login portal (portal.bsum.edu.ng)
- Admin login interfaces (remedial portal)
- Post-UTME verification pages
- Password reset endpoints

2. Academic Publishing System

- Journal directories (/journals/, /files/)
- PDF hosting endpoints
- Research paper repositories

3. Document Exposure Surface

- Admission PDFs
- Staff-related academic research papers
- Examination and academic handbooks

4. Subdomain Expansion Surface

- library.bsum.edu.ng
- jupeb.bsum.edu.ng
- remedial.bsum.edu.ng
- alumni and departmental subdirectories

2. Vulnerability & Weakness Analysis- BSUM

Framework Reference

- CVE (Common Vulnerabilities and Exposures)
- CWE (Common Weakness Enumeration)
- OWASP Top 10: 2025
- API / Web Security Guidelines

1. Legacy Apache Web Server Exposure

Description

OSINT analysis identified that the university's web infrastructure is running **Apache HTTP Server 2.4.41** on an Ubuntu-based environment. While Apache remains one of the most widely deployed web servers globally, older versions may contain publicly disclosed vulnerabilities if security updates and vendor patches have not been consistently applied.

Security Mapping

CVE References

- CVE-2020-1934 – Uninitialized memory usage vulnerability in mod_proxy_ftp.
- CVE-2020-1927 – Improper URL redirection handling through mod_rewrite.
- CVE-2020-13950 – Denial-of-Service vulnerability in mod_proxy_http caused by specially crafted requests.

CWE References

- CWE-1104: Use of Unmaintained Third-Party Components
- CWE-400: Uncontrolled Resource Consumption
- CWE-755: Improper Handling of Exceptional Conditions

OWASP Top 10 (2025)

- A03 – Software Supply Chain Failures
- A02 – Security Misconfiguration

Potential Risk

- Service disruption and denial-of-service attacks
- Unexpected application behavior
- Increased attack surface from legacy software
- Exposure to publicly documented vulnerabilities
- Reduced platform security resilience

2. Authentication Portal Exposure

Description

Multiple internet-facing authentication portals were identified across the university environment, including student registration systems, admissions portals, remedial programme portals, and password recovery interfaces.

Examples include:

- portal.bsum.edu.ng
- remedial.bsum.edu.ng
- Student account authentication services
- Password reset functionality

Security Mapping

CWE References

- CWE-307: Improper Restriction of Excessive Authentication Attempts
- CWE-287: Improper Authentication

OWASP Top 10 (2025)

- A07 –Authentication Failures

Potential Risk

- Brute-force login attempts
- Credential stuffing attacks
- Unauthorized account access
- Student and staff account compromise
- Unauthorized access to academic records

3. Academic Document Exposure

Description

The university hosts academic journals, research publications, admission documents, academic handbooks, and PDF resources through publicly accessible web directories. While most documents are intended for public access, exposed repositories may provide valuable intelligence to malicious actors during reconnaissance activities.

Security Mapping

CWE References

- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

OWASP Top 10 (2025)

- A01 – Broken Access Control

Potential Risk

- Information gathering by attackers
- Institutional profiling
- Exposure of internal academic resources
- Increased effectiveness of phishing and social engineering campaigns

4. Multiple Subdomain Attack Surface

Description

Several subdomains supporting different academic and administrative functions were identified, including admissions, library services, remedial programmes, and JUPEB operations.

Examples include:

- portal.bsum.edu.ng
- library.bsum.edu.ng
- remedial.bsum.edu.ng
- jupeb.bsum.edu.ng

Each additional subdomain introduces a separate attack surface requiring independent security management and monitoring.

Security Mapping

CWE References

- CWE-16: Configuration
- CWE-284: Improper Access Control

OWASP Top 10 (2025)

- A02 – Security Misconfiguration

Potential Risk

- Inconsistent security controls across platforms
- Forgotten or poorly maintained services
- Increased vulnerability management complexity
- Expanded attack opportunities for threat actors

5. PHP-Based Web Application Risk

Description

The university's admissions systems, student portals, and administrative applications rely on PHP-based web technologies. Improper development practices or insufficient input validation may expose applications to common web application vulnerabilities.

Security Mapping

CWE References

- CWE-20: Improper Input Validation
- CWE-79: Cross-Site Scripting (XSS)
- CWE-89: SQL Injection

OWASP Top 10 (2025)

- A05 – Injection
- A06 – Insecure Design

Potential Risk

- Unauthorized access to application data
- Database manipulation
- Information disclosure
- Session compromise
- Loss of data integrity

Risk Assessment Summary

The primary security concerns identified within the university's digital ecosystem include the use of an older Apache web server version, multiple internet-facing authentication systems, publicly accessible document repositories, and a broad subdomain footprint supporting academic operations. While no active exploitation

was performed during this assessment, these findings indicate areas where proactive security hardening, continuous monitoring, patch management, and access control improvements would strengthen the institution's overall cybersecurity posture.

3. THREAT IMPACT & EXPLOITABILITY SCENARIO - BSUM

Primary Risk

Authentication Portal Exposure Combined with Public Information Availability

Attack Scenario

Phase 1: Reconnaissance

An attacker performs Open-Source Intelligence (OSINT) gathering against the university and identifies publicly available digital assets including:

- bsum.edu.ng
- portal.bsum.edu.ng
- library.bsum.edu.ng
- remedial.bsum.edu.ng
- jupeb.bsum.edu.ng

The attacker further collects publicly accessible academic documents, admission materials, research publications, and portal information that may reveal organizational structure and operational processes.

Phase 2: Target Enumeration

The attacker identifies:

- Student authentication portals
- Password recovery mechanisms
- Administrative login interfaces
- Academic publishing systems
- PHP-based applications

These services become potential entry points for credential attacks and web application attacks.

Phase 3: Initial Access Attempt

The attacker attempts:

- Brute-force attacks against student accounts

- Credential stuffing using leaked passwords from external breaches
- Exploitation of application vulnerabilities arising from poor input validation
- Abuse of security weaknesses associated with outdated software components

Phase 4: Post-Compromise Activities

If successful, an attacker could potentially:

- Access student records
- View academic information
- Manipulate portal data
- Disrupt online academic services
- Harvest additional user credentials
- Use compromised accounts for further attacks

CVSS Assessment

Finding	Estimated CVSS	Severity
Legacy Apache Web Server Exposure	6.5	Medium
Authentication Portal Exposure	7.5	High
Academic Document Exposure	5.3	Medium
Multiple Subdomain Attack Surface	5.8	Medium
PHP Application Risk	8.1	High

EPSS Assessment

The identified risks present a Low-to-Moderate likelihood of exploitation depending on the effectiveness of existing security controls.

Factors increasing exploitability include:

- Public accessibility of university services
- Multiple authentication portals
- Publicly available institutional information
- Potential use of legacy software components

Business Impact Analysis

Operational Impact

A successful cyberattack could result in:

- Disruption of student registration activities
- Interruption of admission processes
- Temporary unavailability of academic portals
- Delays in examination and result processing

Academic Impact

Potential consequences include:

- Unauthorized access to academic records
- Exposure of student information
- Loss of confidence in university digital services

Financial Impact

Possible financial consequences include:

- Incident response costs
- Infrastructure recovery expenses
- Additional cybersecurity investment requirements
- Potential regulatory compliance costs

Reputational Impact

The university may experience:

- Reduced stakeholder confidence
- Negative public perception
- Loss of trust among students and staff
- Reputational damage affecting institutional credibility

Regulatory Impact

Where personal data is affected, incidents may result in:

- Nigeria Data Protection Act (NDPA) compliance concerns
- Increased regulatory scrutiny
- Mandatory breach reporting obligations

Overall Risk Rating

Based on the observed attack surface, technology footprint, and exposed authentication systems, the university's overall cyber risk level is assessed as:

Overall Risk Rating: Medium–High

The primary concerns relate to authentication security, software maintenance, and the management of multiple internet-facing academic systems.

4. Mitigation & Technical Remediation Plan - BSUM

Immediate Mitigation (Short-Term)

The following actions should be prioritized to reduce immediate risk exposure:

Authentication Security

- Implement account lockout policies after repeated failed login attempts.
- Deploy CAPTCHA protection on login forms.
- Enforce strong password requirements.
- Review password reset procedures.

Apache Server Security

- Review Apache configuration settings.
- Apply all available security patches.
- Disable unnecessary Apache modules and services.

Subdomain Security Review

- Conduct a security review of all active subdomains.
- Remove unused or deprecated services.
- Verify secure configuration across all university portals.

Academic Resource Protection

- Review publicly accessible directories.
- Restrict access to non-public documents.
- Disable directory listing where unnecessary.

Permanent Remediation (Long-Term)

Security Governance

- Establish a formal cybersecurity governance program aligned with the NIST Cybersecurity Framework.
- Conduct periodic risk assessments across all university systems.

Multi-Factor Authentication (MFA)

- Deploy MFA for administrative accounts.
- Extend MFA implementation to critical university portals.

Patch and Vulnerability Management

- Establish a formal patch management process.
- Regularly update Apache, PHP, operating systems, and application components.
- Monitor vulnerability intelligence sources for emerging threats.

Secure Software Development

- Implement secure coding practices for PHP applications.
- Perform application security testing before deployment.
- Conduct regular vulnerability assessments.

Logging and Monitoring

- Centralize security logs.
- Deploy intrusion detection and monitoring solutions.
- Establish incident response procedures for security events.

Data Protection and Compliance

- Review data handling processes against NDPA requirements.
- Implement appropriate access controls for student information.
- Encrypt sensitive information where applicable.

Verification Strategy

To verify that remediation activities have been successfully implemented, the university should:

1. Conduct periodic vulnerability assessments.
2. Re-perform OSINT reviews to identify exposed resources.

3. Verify Apache and PHP version updates.
4. Test authentication controls and brute-force protections.
5. Review access permissions across academic systems.
6. Validate security configurations on all identified subdomains.
7. Conduct annual cybersecurity and NDPA compliance reviews.

Conclusion

The assessment identified several areas requiring attention within the university's digital infrastructure, particularly relating to authentication security, legacy software exposure, publicly accessible resources, and the management of multiple internet-facing systems. While no active exploitation was performed during this assessment, implementing the recommended remediation measures will significantly strengthen the institution's cybersecurity posture, improve resilience against emerging threats, and support compliance with the Nigeria Data Protection Act (NDPA) and recognized cybersecurity standards.

7.2 SECTOR: HEALTHCARE - Benue State, Nigeria

Organization Name: Institute of Health and Technology, Benue State (IHTBSUTH)

Domain: ihtbsuth.edu.ng

Sector: Healthcare Education

Type: Health Training Institution

Services: Health sciences education, professional healthcare training, student admissions, academic management, institutional administration, and online information services.

1. Organization Profile & Reconnaissance (OSINT) – IHTBSUTH

Organization Overview

The Institute of Health & Technology – Benue State University Teaching Hospital (IHTBSUTH) is a healthcare training institution located in Makurdi, Benue State, Nigeria. The institution provides training in health-related disciplines and supports the development of healthcare professionals through academic programmes, admissions services, and public health education.

The organization maintains an online presence through its official website, which provides information relating to admissions, institutional resources, academic activities, and public engagement. As a healthcare-focused institution, its digital infrastructure forms part of its operational and information dissemination ecosystem.

Target Identification

Item	Details
Organization Name	Institute of Health & Technology – BSUTH
Sector	Healthcare / Health Education
Location	Makurdi, Benue State, Nigeria
Primary Domain	ihtbsuth.edu.ng
Website	www.ihtbsuth.edu.ng
IP Address	147.124.220.58
Hosting Provider	Majestic Hosting Solutions LLC
Hosting Country	United States
Web Server	LiteSpeed
CMS	WordPress 7.0

Item	Details
Page Builder	Elementor 3.35.5
Backend Language	PHP
Database	MySQL
Nameservers	ns21.doveserver.com, ns22.doveserver.com
Registrar	SmartWeb Nigeria
Domain Creation Date	18 November 2025
DNSSEC	Enabled

Digital Footprint

Primary Web Assets

- <https://www.ihtbsuth.edu.ng>

Publicly Identified Resources

- Admissions pages
- About page
- News and Events section
- Contact page
- Resource pages

Social Media References

- Facebook: bsuthmakurdi
- Twitter/X: BSUTHmakurdi

Attack Surface Mapping

1. Public Website Infrastructure

The institution operates a publicly accessible WordPress-based website hosted on LiteSpeed infrastructure.

Observed Technologies

- WordPress 7.0
- Elementor 3.35.5
- PHP
- MySQL
- LiteSpeed Web Server

2. Contact and Form Submission Services

The website utilizes WPForms for user interaction and information requests.

Potential exposed services include:

- Contact forms
- Admission enquiry forms
- Information request forms

3. Content Management System Surface

The site uses WordPress and Elementor, exposing a CMS administration environment.

Potential administrative components include:

- wp-admin
- wp-login
- Plugin management interfaces
- Theme management interfaces

4. Public Information Exposure Surface

Publicly accessible information includes:

- Academic information
- Admission notices
- Institutional contacts
- Healthcare training programmes
- Public announcements

5. Email Infrastructure

Email security records identified include:

- SPF configured
- DMARC configured (p=none)

DNSSEC enabled

2. Vulnerability & Weakness Analysis – IHTBSUTH

Framework References

The identified weaknesses were analyzed using:

- CVE (Common Vulnerabilities and Exposures)
- CWE (Common Weakness Enumeration)
- OWASP Top 10 (2025)
- CVSS v3.1
- EPSS Risk Considerations

1. Outdated Elementor Website Builder Version

Description

Technology fingerprinting identified the use of Elementor Website Builder version 3.35.5 on the Institute of Health & Technology BSUTH website.

Elementor is one of the most widely used WordPress page-building plugins. Public vulnerability databases indicate that versions up to and including 3.35.5 have been associated with several security issues.

Evidence

Detected Technology:

- Elementor 3.35.5
- WordPress 7.0

Relevant CVEs

CVE-2026-32445

- Missing Authorization
- Allows exploitation of improperly configured access controls.

CVE-2026-32352

- DOM-Based Cross-Site Scripting (XSS)
- Allows malicious script execution within user browsers.

CVE-2025-14732

- Stored Cross-Site Scripting (Stored XSS)
- Allows attackers to inject malicious code that executes whenever affected content is viewed.

CWE Mapping

- CWE-862: Missing Authorization
- CWE-79: Cross-Site Scripting (XSS)
- CWE-284: Improper Access Control

OWASP Top 10 Mapping

- A01 – Broken Access Control
- A05 – Injection
- A02 – Security Misconfiguration

Potential Risk

- Website defacement
- Session hijacking
- Credential theft
- Unauthorized content modification
- User browser compromise

2. WordPress CMS Exposure

Description

The institution's website is powered by WordPress.

Although WordPress is a secure platform when properly maintained, it remains a frequent target for attackers because vulnerabilities often arise through outdated plugins, themes, and misconfigurations.

The use of WordPress increases the importance of regular patch management and security monitoring.

Evidence

Detected Technologies:

- WordPress 7.0
- PHP
- MySQL

CWE Mapping

- CWE-1104: Use of Unmaintained Third-Party Components
- CWE-16: Security Configuration Issues

OWASP Top 10 Mapping

- A02 – Security Misconfiguration
- A03 – Software Supply Chain Failures

Potential Risk

- Plugin-based attacks
- Privilege escalation
- Remote code execution through vulnerable extensions
- Website compromise

3. Publicly Accessible Administrative and Admission Portals

Description

Reconnaissance identified multiple publicly accessible sections including:

- Admissions
- Resources
- Contact Portal
- News and Events

Educational institutions commonly provide online forms and user interaction points. If access controls and validation mechanisms are insufficient, these interfaces may become targets for brute-force attacks, credential stuffing, and web application attacks.

CWE Mapping

- CWE-287: Improper Authentication
- CWE-307: Improper Restriction of Excessive Authentication Attempts

OWASP Top 10 Mapping

- A07 – Identification and Authentication Failures

Potential Risk

- Unauthorized account access
- Credential stuffing
- Password guessing attacks
- Account takeover

4. Information Disclosure Through Public Web Content

Description

Google dorking and OSINT activities revealed publicly indexed institutional information including:

- Organizational details
- Academic programmes
- Contact information
- Staff-related references
- Social media links

While intended for public use, such information can be leveraged by threat actors during reconnaissance and social engineering campaigns.

Evidence

Google Dork:

site:ihlbsuth.edu.ng

Indexed Content:

- Admissions information
- Institutional profile
- Public contact details

CWE Mapping

- CWE-200: Exposure of Sensitive Information

OWASP Top 10 Mapping

- A01 – Broken Access Control
- A06 – Insecure Design

Potential Risk

- Phishing attacks
- Social engineering
- Organizational profiling
- Targeted credential theft

5. Hosting and Infrastructure Concentration Risk

Description

OSINT findings identified that the website is hosted on:

- IP Address: 147.124.220.58
- Hosting Provider: Majestic Hosting Solutions LLC
- LiteSpeed Web Server
- Shared hosting infrastructure

Educational institutions hosted on shared infrastructure may face increased risks if neighboring hosted applications are compromised or if server hardening practices are insufficient.

Evidence

- Nameserver: ns21.doveserver.com
- Nameserver: ns22.doveserver.com
- Hosting Infrastructure: Majestic Hosting Solutions LLC

CWE Mapping

- CWE-693: Protection Mechanism Failure

- CWE-16: Security Configuration

OWASP Top 10 Mapping

- A02– Security Misconfiguration

Potential Risk

- Shared-hosting exposure
- Service disruption
- Cross-site compromise
- Infrastructure dependency risks

6. Operational & Human Weaknesses

Description

As a healthcare education institution, IHTBSUTH manages academic records, staff information, and student data. Human-related security weaknesses often present greater risks than technical vulnerabilities.

Observed Risks

Security Awareness Challenges

Users may be vulnerable to:

- Phishing emails
- Credential harvesting attacks
- Fake admission notifications
- Social engineering campaigns

Weak Password Practices

Without strong password policies, users may select predictable passwords that are vulnerable to credential stuffing attacks.

Third-Party Dependency Risk

The website depends on:

- WordPress
- Elementor
- Hosting providers
- External web services

Compromise of any third-party component could affect the institution's services.

CWE Mapping

- CWE-521: Weak Password Requirements

- CWE-798: Use of Hard-coded Credentials
- CWE-640: Weak Password Recovery Mechanism

OWASP Top 10 Mapping

- A07 –Authentication Failures
- A08 – Software and Data Integrity Failures

Potential Risk

- Unauthorized access
- Data breaches
- Account compromise
- Service disruption

Risk Assessment Summary

The primary security concerns identified during passive reconnaissance include the use of Elementor version 3.35.5 with publicly disclosed vulnerabilities, reliance on WordPress-based infrastructure, publicly accessible institutional information, and authentication-related risks common to education-sector web applications.

No active exploitation was performed during this assessment. All findings were derived from publicly available OSINT sources, technology fingerprinting, WHOIS records, DNS information, Google dorking results, and vulnerability intelligence databases.

Overall Vulnerability Rating: Medium–High

The most significant finding is the presence of Elementor 3.35.5, which has publicly documented CVEs affecting access control and cross-site scripting security. Combined with the institution's public-facing educational services, this increases the potential attack surface and warrants prompt patch verification and remediation.

You're out of messages with the most advanced Free model. Responses

3. Threat Impact & Exploitability Scenario – IHTBSUTH

Primary Risk Scenario

Exploitation of WordPress Elementor Vulnerabilities Combined with Public-Facing Educational Portal Exposure

The most relevant risk for the Institute of Health & Technology BSUTH is the combination of:

- Internet-facing WordPress website
- Elementor Website Builder (v3.35.5)
- Public admissions and institutional information pages
- Lack of visible authentication barriers on core web content

This creates an attack surface where a compromise of the CMS layer could lead to full website control and potential data manipulation or service disruption.

Attack Scenario Breakdown

Phase 1: Reconnaissance (OSINT Stage)

An attacker performs passive reconnaissance using:

- Google dorking
- DNS enumeration
- Technology fingerprinting tools

They identify:

- WordPress CMS usage
- Elementor 3.35.5 page builder
- Public institutional pages (admissions, resources, contact)
- Hosting IP: 147.124.220.58

At this stage, the attacker builds a full map of the target's external attack surface.

Phase 2: Vulnerability Identification

From public CVE databases, the attacker identifies known issues affecting:

- Elementor 3.35.5

Including:

- **CVE-2026-32445** – Missing Authorization
- **CVE-2026-32352** – DOM-based XSS
- **CVE-2025-14732** – Stored XSS

These vulnerabilities suggest possible weaknesses in:

- Input validation
- Access control enforcement
- Frontend script execution security

Phase 3: Initial Exploitation Attempt

The attacker may attempt:

- Injecting malicious scripts into vulnerable Elementor widgets (XSS)
- Testing for unauthorized access to restricted actions (authorization bypass)

- Manipulating form inputs or page parameters

If successful, this could allow:

- Execution of malicious JavaScript in user browsers
- Session hijacking of logged-in administrators
- Defacement or content modification of web pages

Phase 4: Privilege Escalation & Persistence

If administrative access is gained through compromised credentials or session hijacking, the attacker could:

- Modify website content (admissions, announcements, notices)
- Upload malicious plugins or scripts
- Create backdoor admin accounts
- Maintain persistent access to the CMS

Phase 5: Impact on Institution

A successful compromise could result in:

Operational Impact

- Website downtime
- Disruption of admission and academic information services
- Loss of access to institutional announcements

Security Impact

- Exposure of administrative access
- Potential compromise of user sessions
- Manipulation of website content

Reputational Impact

- Loss of trust among students and staff
- Public perception of insecurity
- Damage to institutional credibility

Data Risk

- Exposure of publicly stored documents
- Possible leakage of internal administrative information (if backend is accessed)

CVSS-Based Risk Estimation

Finding	Estimated CVSS	Severity
Elementor XSS (Stored/DOM)	7.2 – 8.1	High
Authorization Misconfiguration	7.5	High
CMS Exposure (WordPress)	5.8	Medium
Public OSINT Exposure	5.0	Medium

Overall Exploitability Rating

Medium–High

The exploitability is increased due to:

- Public accessibility of website
- Known vulnerable plugin version (Elementor)
- Lack of visible access restrictions on frontend systems

4. Mitigation & Technical Remediation Plan – IHTBSUTH

Immediate Mitigation (Short-Term Actions)

CMS & Plugin Security

- Update Elementor from 3.35.5 to the latest stable version
- Remove unused plugins and themes
- Disable inactive WordPress components

Web Application Protection

- Implement Web Application Firewall (WAF) such as:
 - Cloudflare WAF
 - Wordfence Security plugin
- Enable XSS and injection filtering rules

Access Control Hardening

- Restrict administrative access to:
 - Trusted IP addresses
 - VPN-only access for admin panels
- Enforce logout timeouts for inactive sessions

Authentication Security

- Enable CAPTCHA on all forms (login, contact, admission)
- Enforce strong password policy
- Enable login attempt limiting (brute-force protection)

Permanent Remediation (Long-Term Fixes)

Secure CMS Governance

- Establish a structured update policy for:
 - WordPress core
 - Plugins (especially Elementor)
 - Themes
- Perform monthly patch cycles

Secure Development Practices

- Validate all input fields (server-side validation)
- Sanitize all user inputs in forms and widgets
- Avoid direct rendering of user-generated content in Elementor

Security Architecture Improvements

- Deploy a dedicated WAF at network edge
- Enable HTTPS with full TLS enforcement (SSL certificate hardening)
- Implement Content Security Policy (CSP) headers to mitigate XSS

Monitoring & Logging

- Enable centralized logging for:
 - Login attempts
 - Admin actions
 - Plugin updates
- Use intrusion detection tools (IDS) to detect abnormal behavior

Infrastructure Hardening

- Periodically scan hosting environment for:
 - Misconfigurations
 - Outdated server software
- Ensure LiteSpeed server is fully patched and secured

Verification Strategy

To confirm remediation effectiveness:

- Re-scan website using OSINT tools to confirm:
 - Elementor version updated
 - No exposed vulnerable plugins
- Perform vulnerability scanning (OWASP ZAP / Burp Suite)
- Test login security:
 - Brute-force protection
 - CAPTCHA enforcement
- Validate HTTP headers:
 - CSP present
 - Security headers enabled
- Conduct periodic penetration testing (quarterly or bi-annually)

Final Summary

The Institute of Health & Technology BSUTH website presents a moderate-to-high risk exposure primarily due to:

- Use of a known vulnerable Elementor version
- WordPress-based CMS attack surface
- Public-facing educational infrastructure
- Potential misconfiguration risks typical in plugin-heavy environments

While no active compromise is observed, maintaining outdated CMS components significantly increases future exploitability risk, especially through XSS and access control weaknesses.

8.0 KOGI STATE ASSESSMENT

8.1 SECTOR – E-COMMERCE – Kogi State, Nigeria

Organization Name:

Jumia Nigeria

Domain Name:

Jumia.com.ng

Assessment Scope:

This assessment focuses on publicly accessible information and passive reconnaissance activities conducted against Jumia Nigeria's publicly available digital infrastructure. No intrusive testing, exploitation attempts, or unauthorized access activities will be performed.

Objectives:

- Identify the organization's digital footprint.
- Map publicly exposed services and attack surfaces.
- Identify observable security weaknesses and outdated technologies.
- Map findings to recognized cybersecurity frameworks (CVE, CWE, OWASP Top 10:2025).
- Assess potential business impact and recommend mitigation strategies.

1. Organization Profile & Reconnaissance (OSINT) - Jumia Ng

Digital Footprint Overview

Jumia Nigeria operates as a large-scale e-commerce marketplace under a distributed digital ecosystem. The platform supports multiple interconnected services that facilitate online retail, vendor management, payments, logistics, and customer engagement.

Target Identification

Item	Details
Organization	Jumia Nigeria
Sector	E-Commerce
Domain	jumia.com.ng

Jumia Nigeria operates as a large-scale e-commerce platform supporting online retail, vendor services, payment systems, and logistics operations.

Digital Footprint

The organization operates a distributed multi-service ecosystem including:

- Main e-commerce platform (jumia.com.ng)
- Vendor management system (vendorhub.jumia.com.ng)

- Payment services (pay.jumia.com.ng)
- API and credit systems (credits-api-doc-pay.jumia.com.ng)
- Blog and content platform (blog.jumia.com.ng)

This shows a **multi-platform architecture supporting both customers and vendors.**

Infrastructure Overview

The platform is built on a cloud-based and globally distributed infrastructure:

- CDN: Cloudflare
- DNS: Amazon Route 53
- Web Server: nginx
- SSL: HTTPS enforced
- Security Layer: CAPTCHA and bot protection

The system is designed for **high availability, scalability, and global traffic handling.**

Attack Surface Mapping

During Dorking, the following exposed services were identified:

Authentication Systems

- /login
- /signin
- /register
- /account

Used for customer authentication and frequently targeted for:

- Credential stuffing
- Brute-force attacks
- Phishing campaigns

Vendor Management System

- vendorhub.jumia.com.ng

Supports vendor operations such as:

- Product listing
- Commission tracking
- Seller management

High-risk area for:

- Vendor account takeover
- Fraudulent listings

API & Backend Services

- credits-api-doc-pay.jumia.com.ng

Supports:

- Payments
- Credit systems
- Transaction processing

Expands exposure to API abuse risks.

E-Commerce Core Systems

- Product browsing
- Cart system
- Checkout and payment flow

Critical business layer handling financial transactions.

2. Vulnerability & Weakness Analysis - Jumia Ng

Framework Reference

Vulnerabilities and security weaknesses identified during this assessment were analyzed using recognized cybersecurity frameworks and industry standards, including:

- Common Vulnerabilities and Exposures (CVE) – for known software vulnerabilities (where applicable)
- Common Weakness Enumeration (CWE) – for structural security weaknesses
- OWASP Top 10:2025 – for web application security risk classification
- OWASP API Security Top 10 – for API-related exposure analysis
- NIST Cybersecurity Guidelines – for risk categorization and control mapping

Technical Flaws

No direct outdated software versions were confirmed. However, the system shows **architectural and exposure-based weaknesses** due to its distributed design.

Key Security Findings

1. Large Distributed Attack Surface

Jumia operates multiple interconnected services:

- Customer platform
- Vendor portal
- Payment systems
- APIs

Risk: More entry points increase likelihood of exploitation.

Mapping:

- CWE: CWE-1059 (Improper System Architecture Exposure)
- OWASP 2025: A06 – Insecure Design

2. Authentication Surface Exposure

Multiple login endpoints exist across services.

Risk:

- Credential stuffing
- Account takeover
- Phishing attacks

Mapping:

- CWE-307 – Excessive Authentication Attempts
- OWASP 2025:
 - A07 – Authentication Failures
 - A01 – Broken Access Control

3. API Exposure Risk

Public-facing APIs support payment and vendor operations.

Risk:

- Unauthorized API access
- Data leakage
- Payment abuse

Mapping:

- CWE-285 – Improper Authorization
- OWASP 2025: A01 – Broken Access Control

4. Third-Party Dependency Risk

External services include:

- Google Analytics
- Facebook Pixel
- TikTok tracking
- New Relic
- Cloudflare tools

Risk:

- Supply chain compromise
- Data leakage via scripts

Mapping:

- CWE-829 – Inclusion of External Functionality
- OWASP 2025: A03 – Software Supply Chain Failures

5. Information Exposure

Public content includes:

- Product listings
- Vendor pages
- Blog content
- API documentation

Risk:

- Easier attacker reconnaissance
- Targeted phishing

Mapping:

- CWE-200 – Information Disclosure
- OWASP 2025: A08- Software or Data Integrity Failure

6. Operational Complexity Risk

Distributed systems and third-party integrations create:

- Monitoring difficulties
- Incident response delays
- Complex security management

Mapping:

- CWE-778 – Insufficient Logging
- OWASP 2025: A09 – Security Logging and Alerting Failures

3. Threat Impact & Exploitability Scenario - Jumia Ng

Introduction

This section evaluates the potential security and business impact of the weaknesses identified in Section 2. Since this assessment is based on passive reconnaissance and publicly available information, the risks described are **probabilistic and scenario-based**, not confirmed active vulnerabilities.

The analysis focuses on how observed architectural and exposure patterns could be leveraged if exploited by a malicious actor.

Risk Assessment Methodology

The risks were evaluated using:

- **Likelihood:** Probability of exploitation based on exposure level and attack surface
- **Impact:** Potential damage to confidentiality, integrity, and availability of the system
- **Business Criticality:** Effect on operations, customers, and brand trust

1. Credential Attacks

Threat:

Attackers target login systems using stolen credentials or brute force.

Impact:

- Account takeover
- Fraudulent purchases
- Loss of user trust

Risk Level: High

2. API Abuse

Threat:

Weak API controls allow unauthorized access or manipulation.

Impact:

- Financial fraud
- Data leaks
- System abuse

Risk Level: High

3. Third-Party Supply Chain Risk

Threat:

Compromised external scripts inject malicious code.

Impact:

- Data theft
- Session hijacking
- User tracking abuse

Risk Level: High

4. Attack Surface Exploitation

Threat:

Attackers scan subdomains for weak entry points.

Impact:

- Partial system compromise
- Lateral movement

Risk Level: High

5. Information Disclosure

Threat:

Public data used for reconnaissance.

Impact:

- Targeted phishing
- System mapping by attackers

Risk Level: Medium

6. Operational Complexity Risk

Threat:

Large distributed system slows detection.

Impact:

- Delayed incident response
- Undetected attacks

Risk Level: High

4. Mitigation & Technical Remediation Plan - Jumia Ng

Overview

This section presents recommended technical and operational mitigation strategies based on the security weaknesses identified during passive reconnaissance of Jumia Nigeria's public-facing infrastructure. Recommendations are divided into immediate mitigations and long-term remediation measures designed to strengthen security posture, reduce attack surface exposure, and improve resilience against cyber threats.

1. Attack Surface Reduction

Immediate:

- Disable unused endpoints
- Review exposed subdomains

Long-term:

- Implement Zero Trust Architecture
- Centralize API gateway control

2. Authentication Security

Immediate:

- Enable CAPTCHA
- Apply rate limiting

Long-term:

- Implement MFA
- Use SSO and adaptive authentication

3. API Security

Immediate:

- Restrict API access
- Apply rate limits

Long-term:

- Implement API gateway security
- Enforce token validation and authorization

4. Third-Party Security

Immediate:

- Remove unused scripts
- Review external dependencies

Long-term:

- Implement CSP and SRI
- Establish supply chain governance

5. Logging & Monitoring

Immediate:

- Enable logging across systems

Long-term:

- Deploy SIEM system
- Establish SOC monitoring

6. Information Exposure Control

Immediate:

- Reduce public system information

Long-term:

- Apply data minimization policies
- Conduct periodic OSINT reviews

Conclusion

Jumia Nigeria operates a mature and highly scalable e-commerce infrastructure supported by multiple interconnected services. However, its distributed architecture increases the overall attack surface and introduces risks related to authentication, APIs, and third-party dependencies.

While no direct software vulnerabilities were identified, the system remains exposed to architectural and operational security risks. Strengthening authentication controls, securing APIs, and improving monitoring will significantly enhance the organization's security posture.

9.0 KWARA STATE ASSESSMENT

9.1 SECTOR – GAMING – Kwara State, Nigeria

Organization Name:

SportyBet Nigeria

Domain Name:

Sportybet.com

1. Organization Profile & Reconnaissance (OSINT) - SportyBet

Organization Overview

SportyBet is an international online betting and gaming platform that provides sports betting, virtual games, live betting, deposits, withdrawals, and account management services. The platform is widely used across Nigeria, including kwara State.

The assessment focused on publicly accessible infrastructure and information obtained through Open-Source Intelligence (OSINT) techniques without attempting unauthorized access.

Basic Information

Item	Details
Organization Name	SportyBet
Sector	Gaming / Online Betting
Location Assessed	kwara State, Nigeria
Primary Domain	sportybet.com
Domain Registration Date	29 January 2003
Domain Expiration Date	29 January 2031
Registrar	Tucows Domains Inc.
Nameserver Provider	Cloudflare
Hosting Infrastructure	Amazon Web Services (AWS)
CDN Services	Amazon CloudFront
DNS Security Extensions (DNSSEC)	Enabled

Public Digital Footprint

Item	Details
Primary Domain	sportybet.com

Item	Details
Registrar	Tucows Domains Inc.
Nameserver Provider	Cloudflare
Hosting Infrastructure	Amazon Web Services (AWS)
Content Delivery Network	Amazon CloudFront
Email Infrastructure	Google Workspace

Identified Domains and Services

Publicly available domain records revealed several internet-facing assets associated with SportyBet.

Asset	Purpose
sportybet.com	Main betting platform
www.sportybet.com	Public web application
mobile.sportybet.com	Mobile betting platform
lite.sportybet.com	Lightweight betting interface
m.sportybet.com	Mobile access portal
livescore.sportybet.com	Sports score tracking service
help.sportybet.com	Customer support portal
ideas.sportybet.com	User feedback and suggestion platform
franchise.sportybet.com	Franchise-related service

Public Infrastructure Discovery

Hosting Information

Item	Observation
Hosting Provider	Amazon Web Services (AWS)
Hosting Country	United States
CDN Provider	Amazon CloudFront
DNS Protection	Cloudflare
Site Rank	4,805 (Netcraft)

Item	Observation
DNSS	Enabled

Google Dorking Findings

The following Google Dorks were used to identify exposed resources:

site:sportybet.com

site:sportybet.com inurl:login

site:sportybet.com inurl:admin

site:sportybet.com "password"

site:sportybet.com "account"

site:sportybet.com "deposit"

site:sportybet.com "payment"

site:sportybet.com "@sportybet.com"

site:sportybet.com filetype:pdf

Attack Surface Mapping

Publicly accessible services identified during reconnaissance include:

- User registration portal
- User login portal
- Password recovery service
- User account management pages
- Deposit and withdrawal functions
- Identity verification service
- Customer support portal
- Mobile betting platform
- Live betting services

Several public subdomains were also identified, including:

- www.sportybet.com
- mobile.sportybet.com
- lite.sportybet.com
- help.sportybet.com
- livescore.sportybet.com

- No publicly indexed administrative portal or sensitive document repository was discovered during the reconnaissance phase.

Key Findings

- SportyBet maintains a large public-facing infrastructure supporting betting and financial transactions.
- Multiple internet-accessible services handle user authentication, account management, and payment-related activities.
- Cloudflare, AWS, and Amazon CloudFront are used to improve availability and protection of online services.

Reconnaissance Observations

The assessment identified a large internet-facing infrastructure supported by Amazon Web Services, Cloudflare, and Google Workspace services.

Multiple public-facing services handle authentication, deposits, withdrawals, identity verification, and customer account management. These services represent the primary attack surface exposed to external users.

No publicly exposed administrative interfaces, sensitive documents, or misconfigured cloud storage resources were discovered during this reconnaissance phase. However, the large number of user-facing financial and account management services increases the importance of strong authentication, access control, and transaction security mechanisms.

2. Vulnerability & Weakness Analysis - SportyBet

Finding 1: Publicly Accessible Authentication Services

SportyBet exposes several authentication-related functions including login, registration, account recovery, and identity verification services. These services represent attractive targets for credential stuffing, brute-force attacks, and account takeover attempts.

Framework Mapping

Standard	Mapping
CWE	CWE-307: Improper Restriction of Excessive Authentication Attempts
OWASP Top 10 (2025): A07	Authentication Failures

Finding 2: Large Public Attack Surface

Multiple publicly accessible subdomains were identified including mobile, lite, help, livescore, and franchise services. Every additional internet-facing service increases the organization's exposure to potential attacks.

Framework Mapping

Standard	Mapping
CWE	CWE-284: Improper Access Control
OWASP Top 10 (2025): A01	Broken Access Control

Finding 3: Email Spoofing Exposure Risk

The domain implements DMARC with a quarantine policy rather than a reject policy.

V=DMARC1; P=quarantine

While this provides protection against spoofed emails, suspicious messages may still reach user spam folders rather than being completely blocked.

Framework Mapping

Standard	Mapping
CWE	CWE-290: Authentication Bypass by Spoofing
OWASP Top 10 (2025)	Identification and Authentication Failures
CVE	Not applicable

Finding 4: Financial Transaction Exposure

The platform publicly exposes deposit, withdrawal, and payment processing functionalities. These services are common targets for fraud, phishing, account takeover, and transaction manipulation attacks.

Framework Mapping

Standard	Mapping
CWE	CWE-602: Client-Side Enforcement of Server-Side Security
OWASP Top 10 (2025)	Insecure Design
CVE	No specific CVE identified during assessment

Operational & Human Weaknesses

Social Engineering Risk

Publicly available support email addresses and customer support channels could be leveraged by attackers to conduct phishing campaigns against customers.

Fraud and Account Takeover Risk

Because the platform processes financial transactions and stores user accounts, successful credential theft could lead to unauthorized betting activities, fraudulent withdrawals, and reputational damage.

3. Threat Impact & Exploitability Scenario – SportyBet

CVSS Scoring (Risk Severity Assessment)

Based on the identified weaknesses (authentication exposure, large attack surface, DMARC misconfiguration, and financial transaction services), the primary risk is **Account Takeover via Authentication Abuse (Credential Stuffing / Brute Force)**.

Primary Risk Scenario:

- Weak restriction on authentication attempts (CWE-307)
- Publicly exposed login and account recovery endpoints
- High-value financial accounts (deposits, withdrawals, betting wallet)
-

CVSS v3.1 Score (Estimated): 8.8 – High

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Scope	Changed
Confidentiality Impact	High
Integrity Impact	High
Availability Impact	Medium

Justification:

Attackers can remotely target login endpoints without authentication, and successful exploitation leads directly to financial account compromise.

EPSS (Exploit Probability Assessment)

- **EPSS Estimate:** High (0.75 – 0.85 range)
- Reason:
 - Login endpoints are continuously targeted globally
 - Automated botnets perform credential stuffing at scale
 - Financial platforms are high-value targets for attackers

Attack Vector & Exploitation Scenario**Step-by-Step Attack Scenario (Realistic Threat Model)****1. Reconnaissance Phase**

Attacker identifies:

- sportybet.com/login
- mobile.sportybet.com

Collects leaked credentials from external data breaches

2. Automated Credential Stuffing

- Botnet attempts login using reused credentials
- No or weak rate limiting allows repeated attempts

3. Account Takeover (ATO)

- Successful login grants access to:
 - Betting wallet
 - Deposit history
 - Withdrawal methods

4. Financial Exploitation

- Attacker performs:
 - Unauthorized withdrawals
 - Betting manipulation
 - Account resale on dark markets

5. Covering Tracks

- Uses VPN/proxies

- Exploits lack of anomaly detection alerts

Business Impact Analysis

Financial Impact

- Direct user fund loss (fraudulent withdrawals)
- Chargebacks and dispute handling costs
- Potential regulatory penalties (data protection & fintech compliance)

Operational Impact

- Increased customer support load (account recovery cases)
- Platform monitoring and incident response overhead
- Temporary suspension of suspicious transactions

Reputational Impact

- Loss of user trust in platform security
- Negative media coverage of account compromise incidents
- Reduced user engagement and betting activity

Regulatory Impact

- Possible exposure under Nigeria Data Protection Regulation (NDPR)
- International compliance risks (if users are global)

4. Mitigation & Technical Remediation Plan - SportyBet

Immediate Mitigation (Short-Term Controls)

These are urgent actions to reduce active exploitation risk:

Authentication Protection

- Implement strict **rate limiting** on login endpoints
- Add **IP-based throttling**
- Enable **account lockout after repeated failed attempts**
- Deploy **bot detection (CAPTCHA / behavioral analysis)**

Session Security

- Force session expiration after suspicious activity
- Enforce secure cookie flags (HttpOnly, Secure, SameSite)

Email Spoofing Protection

- Upgrade DMARC policy:
v=DMARC1; p=reject;
- Enforce SPF and DKIM alignment

Monitoring & Detection

- Enable real-time alerts for:
 - Multiple login failures
 - Geo-location anomalies
 - Sudden withdrawal attempts

Permanent Remediation (Long-Term Fixes)

Strong Authentication Controls

- Enforce **Multi-Factor Authentication (MFA)** for:
 - Logins
 - Withdrawals
 - Password resets
- Implement **adaptive authentication (risk-based login)**

Advanced Anti-Bot Protection

- Deploy WAF rules (AWS WAF / Cloudflare WAF)
- Add:
 - Device fingerprinting
 - Behavioral analytics
 - CAPTCHA v3 or invisible challenge systems

Secure Access Control Improvements

- Implement **role-based access control (RBAC)**
- Harden API endpoints to prevent unauthorized access
- Apply **principle of least privilege**

Infrastructure Hardening

- Regular penetration testing of:
 - Subdomains (mobile, lite, help portals)
- Patch management for all backend services
- API gateway security enforcement

Verification Strategy (How to Confirm Fix is Working)

Security Testing

- Perform controlled:
 - Credential stuffing simulation
 - Brute force testing (with rate limits verified)
- Confirm lockout triggers correctly

Monitoring Validation

- Check logs for:
 - Reduced failed login attempts
 - Blocked IP addresses
 - CAPTCHA activation events

Penetration Reassessment

- Re-run OSINT and vulnerability scanning:
 - Ensure no exposed login bypass
 - Validate DMARC = reject
 - Confirm WAF rules are active

User Security Validation

- Attempt:
 - Password reset abuse test
 - Session hijacking simulation
- Confirm MFA enforcement across critical endpoints

Conclusion

This assessment of SportyBet Nigeria identified a large and complex online infrastructure supporting betting, account management, and financial transactions. The platform's wide range of public-facing services increases its overall attack surface and exposure to potential cyber threats.

Key risks identified include authentication weaknesses, exposure of multiple subdomains, and the sensitivity of financial transaction systems. These issues make the platform a potential target for attacks such as credential stuffing, account takeover, and phishing.

Although no critical system-level vulnerabilities or exposed administrative interfaces were found, the security of user authentication and financial services remains a key concern.

Implementing the recommended security controls will help reduce risk, strengthen user protection, and improve overall system resilience.

9.2 SECTOR: INSURANCE - Kwara State, Nigeria

Organization Name: Leadway Assurance Company Limited

Domain: leadway.com

Sector: Insurance Company

Services: Life Insurance, Auto Insurance, Health Insurance, Property Insurance, Travel Insurance, Pension Solutions, Wealth Management, Investment Services, Claims Management

1. Organization Profile & Reconnaissance (OSINT) – Leadway

Organization Overview

Leadway Assurance Company Limited is one of Nigeria's largest insurance providers offering life insurance, health insurance, motor insurance, travel insurance, annuities, pension management, and corporate risk management solutions. The organization maintains numerous internet-facing applications supporting customers, brokers, agents, internal staff, and third-party partners.

The company's digital infrastructure consists of customer self-service portals, payment systems, policy management applications, cloud-hosted services, API endpoints, risk governance systems, and multiple public-facing websites.

Target Identification

Item	Details
Organization Name	Leadway Assurance Company Limited
Sector	Insurance & Financial Services
Headquarters	Lagos, Nigeria
Primary Domain	leadway.com
Hosting Providers	Cloudflare, Microsoft Azure, MainOne Cloud Infrastructure
ASN Providers	AS13335 (Cloudflare), MainOne
Public IP Examples	154.113.4.93, 154.113.4.99, 154.113.4.171, 154.113.4.239
Cloud Infrastructure	Microsoft Azure
CDN Provider	Cloudflare
SSL Providers	DigiCert, Let's Encrypt, Google Trust Services
Email Platform	Microsoft 365 / Azure AD
Web Application Firewall	Cloudflare WAF
Load Balancer	Cloudflare Load Balancer
Identity Services	Azure Active Directory Federation Services

Technology Stack Identified

Public technology fingerprinting via Shodan revealed the following technologies:

Technology	Evidence
WordPress CMS	www.leadway.com
Apache HTTP Server	Multiple hosts identified
Microsoft IIS	mc.leadway.com
Microsoft ASP.NET	Azure-hosted systems
Microsoft HTTP API	Multiple exposed endpoints
F5 NGINX	iGRCS platform
Cloudflare WAF	Multiple public assets
Cloudflare Load Balancer	Multiple public assets
Microsoft Azure Application Gateway	Azure infrastructure
Microsoft Kestrel Web Server	Swagger/API services
Swagger UI	Public API documentation endpoint
PHP	Multiple web applications
Cisco HTTP Service	la1-ftd01.leadway.com
Azure AD Federation Services	Identity management

Digital Footprint

Primary Web Assets

- <https://www.leadway.com>
- <https://careers.leadway.com>
- <https://apps.leadway.com>
- <https://agric.leadway.com>
- <https://annuity.leadway.com>
- <https://auto.leadway.com>
- <https://assessment.leadway.com>
- <https://fire.leadway.com>
- <https://householder.leadway.com>
- <https://staging.leadway.com>

- <https://track.sl.leadway.com>

Observed Functional Systems

Insurance Services

- Auto insurance platform
- Life insurance platform
- Fire insurance platform
- Householder insurance portal
- Agricultural insurance portal
- Annuity services

Corporate Systems

- Integrated Governance Risk & Compliance Solution (iGRCS)
- Compliance management portal
- Risk management platform
- Internal reporting systems
- Corporate applications

Customer Services

- Policy purchase systems
- Online quotation systems
- Claims management services
- Customer account portals

Recruitment Systems

- careers.leadway.com

API Services

- Swagger UI exposed services
- Microsoft Kestrel API endpoints

Attack Surface Mapping

1. Authentication Systems

Observed login services include:

- Azure AD Federation authentication
- iGRCS Login Portal

- Career management login systems
- Corporate application portals

Potential attack surfaces:

- Credential stuffing
- Password spraying
- Session hijacking
- Account takeover attacks

2. Customer Insurance Portals

Observed services:

- Policy management
- Insurance purchases
- Claims submission
- Payment processing

Potential risks:

- Broken authentication
- Sensitive data exposure
- Session management flaws

3. API Exposure Surface

Publicly visible services:

- Swagger UI
- Microsoft Kestrel endpoints

Observed Host:

- 154.113.4.99:8806
- 154.113.4.171:8806

Potential attack surface:

- API endpoint enumeration
- Token abuse
- Authorization bypass
- API misconfiguration

4. Governance and Compliance Platforms

Discovered systems:

- iGRCS Studio
- iGRCS Risk
- iGRCS Compliance
- iGRCS Assurance
- iGRCS Reporting

Observed Ports:

- 8801
- 8802
- 8803
- 8805
- 8807
- 8808
- 8810

Potential risks:

- Internal application exposure
- Authentication weaknesses
- Unauthorized access attempts

5. Staging and Development Exposure

Discovered Subdomain:

- staging.leadway.com

Potential concerns:

- Non-production environments exposed to the Internet
- Configuration weaknesses
- Reduced security controls
- Information disclosure

6. Infrastructure Exposure

Observed Public Services:

Service	Port
HTTP	80
HTTPS	443
Custom Web Applications	8801-8810
Management Interface	8443
Secure Administration	9443

The presence of multiple custom application ports significantly expands the organization's internet-facing attack surface.

2. Vulnerability & Weakness Analysis – Leadway

Technical Flaws Identified

Finding 1: Publicly Accessible Swagger UI Interface

Evidence

Shodan identified:

- 154.113.4.99:8806
- 154.113.4.171:8806

Technology:

- Microsoft Kestrel Web Server
- Swagger UI

Security Concern

Swagger UI can expose:

- API routes
- Request structures
- Response formats
- Authentication methods

Attackers may use this information for API enumeration and reconnaissance.

Framework Mapping

Standard	Classification
CWE	CWE-200 Information Exposure
CWE	CWE-213 Exposure of Sensitive Information

Standard	Classification
OWASP API Security	API9: Improper Inventory Management
OWASP Top 10	A02 Security Misconfiguration

Finding 2: Exposed Staging Environment

Evidence

- staging.leadway.com

Security Concern

Internet-accessible staging systems often:

- Contain test accounts
- Run older software
- Have weaker security controls

Framework Mapping

Standard	Classification
CWE	CWE-16 Configuration Errors
CWE	CWE-200 Information Exposure
OWASP Top 10	A02 Security Misconfiguration

Finding 3: WordPress Content Management System Detected

Evidence

- www.leadway.com

Technology:

- WordPress CMS

Security Concern

Version information was not publicly disclosed. However, WordPress remains a frequent attack target due to:

- Plugin vulnerabilities
- Theme vulnerabilities
- Authentication attacks
- Admin panel targeting

Framework Mapping

Standard	Classification
CWE	CWE-1395 Dependency Vulnerability
OWASP Top 10	A06 Vulnerable and Outdated Components

Finding 4: Apache Test Page Exposure

Evidence

- 154.113.4.97
- Apache HTTP Server Test Page Powered by Linux

Security Concern

A default Apache test page may indicate:

- Misconfigured web server
- Unused internet-facing host
- Incomplete hardening process

Framework Mapping

Standard	Classification
CWE	CWE-16 Configuration
OWASP Top 10	A05 Security Misconfiguration

Finding 5: Multiple Public Administrative Interfaces

Observed systems:

- iGRCS Studio
- Risk Portal
- Compliance Portal
- Assurance Portal
- Reporting Portal

Ports:

- 8801–8810

Security Concern

Administrative portals increase exposure to:

- Brute-force attacks

- Credential stuffing
- Session attacks
- Access control weaknesses

Framework Mapping

Standard	Classification
CWE	CWE-287 Improper Authentication
CWE	CWE-306 Missing Authentication
OWASP Top 10	A01 Broken Access Control
OWASP Top 10	A07 Identification and Authentication Failures

Operational & Human Weaknesses

Third-Party Dependency Risk

Leadway relies on:

- Cloudflare
- Microsoft Azure
- Zoho Services
- Microsoft 365

A compromise affecting any third-party provider could affect Leadway operations.

Social Engineering Risk

Publicly discoverable infrastructure provides attackers with information useful for:

- Phishing campaigns
- Business Email Compromise (BEC)
- Credential harvesting

Employee Credential Reuse

The large number of authentication portals increases the risk of:

- Password reuse
- Credential stuffing
- Unauthorized account access

3. Threat Impact & Exploitability Scenario – Leadway

CVSS Scoring

Vulnerability: Public Exposure of Administrative and API Management Interfaces

CVSS v3.1 Base Score: 8.2 (High)

CVSS Vector

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L

Explanation

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality Impact	High
Integrity Impact	Low
Availability Impact	Low

The vulnerability can be exploited remotely over the internet without physical access.

EPSS Assessment

Because the exposed services involve publicly accessible administrative and API-related interfaces, similar weaknesses frequently attract automated scanning and exploitation.

Estimated EPSS Range: 0.45 – 0.70 (Moderate to High)

Justification

Factors increasing exploitation probability:

- Internet-facing services
- Discoverable through Shodan
- Administrative functionality exposed
- Presence of API documentation
- Financial services sector attractiveness

Attack Vector

Possible Attack Scenario

Phase 1: Reconnaissance

An attacker performs OSINT using:

- Shodan
- whois
- Censys
- Google Dorking
- Buildwith
- Netcraft

The attacker discovers:

- Swagger UI interfaces
- iGRCS portals
- Azure-based services
- WordPress infrastructure
- Staging environment

Phase 2: Enumeration

Using the exposed Swagger UI:

- API routes are identified
- Request structures are examined
- Authentication mechanisms are analyzed
- Endpoint inventory is created

The attacker gains insight into internal application architecture.

Phase 3: Initial Access

Potential attack methods:

- Credential stuffing against login portals
- Password spraying attacks
- Abuse of weak API authentication
- Exploitation of configuration weaknesses

Possible targets:

- Customer accounts

- Employee accounts
- Administrative interfaces

Phase 4: Privilege Escalation

If access is obtained:

- Administrative functions may be discovered
- Additional APIs may be enumerated
- Internal systems may become accessible

Phase 5: Data Exposure

Potentially exposed information:

- Customer policy information
- Claims records
- Internal compliance documents
- Risk management reports
- Employee information

Business Impact

Regulatory Impact

Leadway processes sensitive customer information.

Potential regulatory implications include:

- Nigeria Data Protection Act (NDPA) violations

Potential financial penalties could be significant depending on breach scope.

Operational Impact

Potential consequences include:

Impact Area	Potential Effect
Insurance Services	Service disruption
Claims Processing	Delays
Customer Portals	Downtime
Internal Systems	Reduced productivity
Business Operations	Operational disruption

Reputational Impact

Potential outcomes:

- Loss of customer confidence
- Negative media attention
- Reduced policy renewals
- Brand damage

For financial institutions and insurance companies, reputational damage may have long-term business consequences.

Financial Impact

Potential costs may include:

- Incident response expenses
- Digital forensic investigations
- Legal costs
- Regulatory penalties
- Customer notification costs
- Security remediation projects

A significant breach could result in millions of naira in direct and indirect losses.

4. Mitigation & Technical Remediation Plan – Leadway

Immediate Mitigation (Short-Term)

1. Restrict Administrative Interfaces

Administrative portals should not be publicly accessible.

Recommended actions:

- Implement IP allow-listing
- Restrict access to corporate VPN users
- Enable geolocation restrictions

Affected services:

- iGRCS portals
- Swagger interfaces
- Management consoles

2. Disable Public Swagger UI Access

Where API documentation is not intended for public users:

- Remove public access
- Require authentication
- Limit access to developers only

3. Review Staging Environment Exposure

For staging.leadway.com:

- Restrict public access
- Enforce authentication controls
- Disable unnecessary services

4. Strengthen Authentication Controls

Implement:

- Multi-Factor Authentication (MFA)
- Password complexity policies
- Account lockout controls
- Conditional access policies

Particularly for:

- Administrative accounts
- Risk management systems
- Compliance platforms

5. Conduct Emergency Configuration Review

Review:

- Firewall rules
- Cloudflare configurations
- Azure Application Gateway settings
- Web server configurations

Permanent Remediation (Long-Term)

1. Implement Zero Trust Architecture

Security controls should assume no user or system is inherently trusted.

Controls include:

- Continuous verification
- Identity-based access controls
- Device trust validation

2. Secure API Management Framework

Implement:

- API gateway protection
- Token validation
- Rate limiting
- API inventory management

Recommended standards:

- OWASP API Security Top 10
- NIST SP 800-204

3. Harden Web Infrastructure

For WordPress and Apache environments:

- Remove unused services
- Disable default pages
- Enforce secure headers
- Apply continuous patch management

4. Continuous Vulnerability Management

Establish:

- Monthly vulnerability assessments
- Quarterly penetration testing
- Continuous attack surface monitoring

Tools may include:

- Nessus
- Qualys
- OpenVAS

- Microsoft Defender Vulnerability Management

5. Security Awareness Program

Conduct regular training covering:

- Phishing awareness
- Credential security
- Social engineering attacks
- Secure remote access

6. Third-Party Risk Management

Implement vendor risk assessments for:

- Cloudflare
- Microsoft Azure
- Zoho
- Other third-party providers

Verification Strategy

Verification Step 1: External Attack Surface Review

Perform periodic verification using:

- Shodan
- Censys
- SecurityTrails

Expected result: Administrative interfaces no longer publicly visible.

Verification Step 2: Vulnerability Scanning

Run authenticated vulnerability scans against:

- Web applications
- APIs
- Administrative systems

Expected result: No critical or high-risk findings.

Verification Step 3: Access Control Validation

Verify:

- MFA enforcement
- Role-based access controls
- VPN restrictions

Expected result: Unauthorized users cannot access sensitive systems.

Verification Step 4: Penetration Testing

Conduct annual penetration testing to validate:

- Authentication controls
- API security
- Network segmentation
- Administrative portal protection

Expected result: No exploitable paths leading to sensitive assets.

Verification Step 5: Security Monitoring Validation

Confirm that:

- SIEM alerts are functioning
- Failed login attempts are logged
- API abuse detection is active
- Security incidents generate alerts

Expected result: Continuous monitoring detects suspicious activity in real time.

Conclusion

OSINT analysis indicates that Leadway maintains a relatively mature security posture through the use of Cloudflare WAF, Azure security services, SSL encryption, and load balancing technologies. However, publicly exposed administrative interfaces, API documentation endpoints, staging environments, and multiple internet-facing applications increase the organization's attack surface and should be prioritized for remediation to reduce the likelihood of unauthorized access and data exposure.

10. NASARAWA STATE ASSESSMENT

10.1 SECTOR: E-commerce - Nasarawa State, Nigeria

Organization Overview

Organization Name: Konga Group

Website: konga.com

Sector: E- Commerce

Type: Online Marketplace

Services: Online buying and selling platform, delivery services, pickup/drop-off solutions

1. Organization Profile & Rconnaissance (OSINT) – Konga Group

Organization Overview

Konga is one of Nigeria's leading e-commerce and digital commerce platforms, providing online retail, logistics, payment processing, affiliate services, merchant onboarding, and marketplace operations. The organization supports millions of online transactions and maintains multiple interconnected platforms supporting customers, merchants, logistics partners, and corporate operations.

Its digital infrastructure includes customer-facing shopping systems, merchant management portals, logistics services, payment solutions, affiliate platforms, and corporate websites, creating a broad internet-facing attack surface.

Target Identification

Item	Details
Organization Name	Konga Group
Sector	E-Commerce
Headquarters	Lagos, Nigeria
Primary Domain	konga.com
Primary IP Address	104.19.160.200
IPv6 Address	2606:4700::6810:5fc2
Hosting Provider	Cloudflare
ASN	AS13335
Registrar	Register.com / Network Solutions
Domain Creation Date	April 18, 2002
Nameservers	chad.ns.cloudflare.com, melinda.ns.cloudflare.com

Item	Details
CDN Provider	Cloudflare
Frameworks Detected	Next.js, React
Programming Environment	Node.js
Additional CMS Presence	WordPress (blog-related content)
Storage/CDN Services	Amazon S3, Cloudinary
Email Services	Google Workspace, SendGrid, Mandrill
SSL Provider	DigiCert

Digital Footprint

Primary Web Assets

- <https://www.konga.com>
- <https://group.konga.com>
- <https://affiliate.konga.com>
- <https://shq.konga.com>
- <https://logistics.konga.com>
- <https://backend.konga.com>

Observed Functional Systems

- Customer shopping platform
- Seller HQ management portal
- Affiliate marketing platform
- Konga Logistics platform
- KongaPay services
- Corporate management portal
- Customer support services
- Merchant onboarding platform

Attack Surface Mapping

1. Authentication Systems

Observed internet-facing login systems include:

- www.konga.com/account/login

- shq.konga.com/account/login
- Affiliate account login systems
- Seller onboarding and registration systems

Potential attack surface:

- Customer accounts
- Merchant accounts
- Seller dashboards
- Password recovery workflows

2. E-Commerce Platform

Observed services:

- Product catalog systems
- Shopping cart functionality
- Checkout systems
- Customer account management

Potential risks:

- Account takeover attacks
- Payment fraud attempts
- Session hijacking
- Credential stuffing

3. Logistics and API Services

Observed systems:

- logistics.konga.com
- API integration portal

Publicly visible references indicate API integration functionality supporting logistics operations.

Potential attack surface:

- API endpoints
- Authentication tokens
- Third-party integrations

4. Staging and Backend Systems

Google dorking and DNS enumeration identified references including:

- az-backend-staging.konga.com
- backend.konga.com
- staging-group-admin.konga.com

Potential concerns:

- Exposure of development environments
- Configuration inconsistencies
- Reduced security controls compared to production systems

5. Document Exposure Surface

Publicly accessible documents identified include:

- Merchant orientation documents
- Logistics rate sheets
- Corporate documents
- Marketing materials

Potential risks:

- Organizational profiling
- Social engineering support
- Information disclosure

6. Subdomain Expansion Surface

Discovered subdomains include:

- affiliate.konga.com
- backend.konga.com
- blog.konga.com
- community.konga.com
- logistics.konga.com
- group.konga.com
- shq.konga.com
- az-backend-staging.konga.com

Each subdomain introduces an additional attack surface requiring independent security monitoring and governance.

2. Vulnerability & Weakness Analysis – Konga Group

Framework Reference

- CVE (Common Vulnerabilities and Exposures)
- CWE (Common Weakness Enumeration)
- OWASP Top 10 (2025)
- NIST Cybersecurity Framework

1. Multiple Internet-Facing Authentication Portals

Description

Multiple publicly accessible authentication systems were identified supporting customers, sellers, affiliates, and administrators.

Examples:

- www.konga.com/account/login
- shq.konga.com/account/login
- staging-group-admin.konga.com

Security Mapping

CWE References

- CWE-287: Improper Authentication
- CWE-307: Improper Restriction of Excessive Authentication Attempts

OWASP Top 10 (2025)

- A07 – Authentication Failures

Potential Risk

- Credential stuffing attacks
- Brute-force attacks
- Account takeover
- Unauthorized access to customer and merchant accounts

2. Publicly Accessible Staging and Backend Infrastructure

Description

OSINT and Google dorking identified publicly accessible references to backend and staging environments.

Examples:

- az-backend-staging.konga.com
- staging-group-admin.konga.com
- backend.konga.com

While no exploitation was performed, publicly exposed staging environments commonly increase organizational risk.

Security Mapping

CWE References

- CWE-200: Exposure of Sensitive Information
- CWE-16: Security Configuration

OWASP Top 10 (2025)

- A02 – Security Misconfiguration

Potential Risk

- Information disclosure
- Exposure of test functionality
- Configuration leakage
- Increased reconnaissance opportunities

3. Broad Subdomain Attack Surface

Description

DNS reconnaissance identified more than one hundred associated subdomains and host references.

Security Mapping

CWE References

- CWE-284: Improper Access Control
- CWE-16: Configuration

OWASP Top 10 (2025)

- A02 – Security Misconfiguration

Potential Risk

- Forgotten assets
- Shadow IT exposure
- Unpatched systems
- Increased attack opportunities

4. API Exposure and Third-Party Integrations

Description

Konga Logistics publicly advertises API integration services for business partners and logistics operations.

Security Mapping

CWE References

- CWE-306: Missing Authentication for Critical Function
- CWE-862: Missing Authorization

OWASP API Security Top 10

- API1: Broken Object Level Authorization
- API2: Broken Authentication

Potential Risk

- Unauthorized API access
- Data exposure
- Abuse of business workflows
- Transaction manipulation

5. WordPress Content Infrastructure Exposure

Description

WhatCMS identified WordPress components within portions of the Konga ecosystem, particularly blog-related resources.

Security Mapping

CWE References

- CWE-1104: Use of Unmaintained Third-Party Components

OWASP Top 10 (2025)

- A08 – Software and Data Integrity Failures

Potential Risk

- Plugin vulnerabilities
- Theme vulnerabilities
- Content management compromise
- Website defacement

6. Operational & Human Weaknesses

Description

As a large e-commerce platform handling customer transactions and merchant relationships, Konga faces several non-technical security risks.

Human and Operational Risks

- Phishing attacks targeting customers
- Social engineering against support staff
- Credential reuse by customers
- Third-party vendor compromise
- Insider threats
- Merchant account abuse
- Customer service impersonation scams

Security Mapping

CWE References

- CWE-798: Use of Hard-Coded Credentials
- CWE-640: Weak Password Recovery Mechanism

OWASP Top 10 (2025)

- A06 – Insecure Design
- A07 – Authentication Failures

3. Threat Impact & Exploitability Scenario– Konga Group

Overview

The information gathered through Google dorking did not reveal any confirmed security vulnerabilities within Konga's infrastructure. However, the results demonstrate the amount of publicly accessible information available about the organization. In cybersecurity, attackers often begin with reconnaissance to collect information about a target before attempting exploitation. Therefore, understanding these exposures helps assess potential risks and strengthen defensive measures.

Authentication Portal Risks

Findings

Public login portals were identified on Konga's customer and merchant platforms:

- www.konga.com/account/login
- shq.konga.com/account/login

Potential Risks

- Credential stuffing attacks using leaked usernames and passwords
- Brute-force password guessing attempts
- Phishing campaigns targeting Konga users
- Account takeover attacks

Risk Level: Medium

Impact

Successful compromise of customer or merchant accounts could result in:

- Unauthorized purchases
- Exposure of personal information
- Financial losses
- Damage to customer trust

Staging Environment Exposure

Findings

A staging administrative dashboard was discovered:

- staging-group-admin.konga.com

Potential Risks

- Exposure of development or testing systems
- Leakage of software version information
- Misconfigured security controls
- Accidental exposure of sensitive data

Risk Level: High

Impact

If improperly secured, staging environments may provide attackers with valuable information regarding:

- Internal application architecture
- Authentication mechanisms
- Backend technologies
- Configuration settings

Such information could assist in planning future attacks against production systems.

Public Document Exposure

Findings

Several PDF documents were publicly accessible, including:

- Merchant orientation materials
- Logistics rate cards
- Marketing resources

Potential Risks

- Metadata disclosure
- Exposure of employee names and email addresses
- Disclosure of internal business processes
- Information gathering for social engineering

Risk Level: Medium

Impact

Attackers can use document metadata and organizational information to create highly targeted phishing attacks against employees, partners, or customers.

Contact Information Exposure

Findings

Public support resources disclosed:

- Email addresses
- Customer support phone numbers
- WhatsApp support channels

Potential Risks

- Social engineering attacks
- Phishing campaigns
- Impersonation of support staff
- Business email compromise attempts

Risk Level: Medium

Impact

Cybercriminals may use publicly available contact information to impersonate Konga representatives and deceive customers into revealing sensitive information.

Subdomain Enumeration Risks

Findings

Multiple subdomains were identified, including:

- group.konga.com
- backend.konga.com
- logistics.konga.com
- affiliate.konga.com
- blog.konga.com
- shq.konga.com

Potential Risks

- Increased attack surface
- Forgotten or unmanaged assets
- Vulnerable third-party services
- Misconfigured applications

Risk Level

Medium to High

Impact

Each subdomain represents a potential entry point that attackers may investigate for vulnerabilities or security misconfigurations.

API Exposure Risks

Findings

Public references to API integration services were identified through logistics-related resources.

Potential Risks

- API abuse
- Broken authentication
- Excessive data exposure
- Unauthorized access attempts

Risk Level: Medium

Impact

Poorly secured APIs can become attractive targets because they often provide direct access to backend functionality and business data.

Overall Risk Assessment

Area	Risk Level
Authentication Portals	Medium
Staging Environment	High
Public Documents	Medium
Contact Information	Medium
Subdomains	Medium-High
APIs	Medium

Overall Assessment

Based on the reconnaissance results, Konga appears to maintain a significant online presence with multiple public-facing services and platforms. While no direct vulnerabilities were identified through Google dorking alone, the exposed information could support future reconnaissance, social engineering, credential attacks, or targeted exploitation attempts.

The most significant concern identified during this assessment is the presence of a publicly discoverable staging administrative environment, which should be carefully reviewed to ensure proper access controls and security configurations are in place.

4. Mitigation & Technical Remediation Plan-Konga Group

Strengthen Authentication Security

Since publicly accessible login portals were identified, Konga should implement strong authentication controls to reduce the risk of unauthorized access.

Recommendations

- Enforce Multi-Factor Authentication (MFA) for customers, merchants, and administrators.
- Implement account lockout mechanisms after multiple failed login attempts.
- Deploy CAPTCHA protections to prevent automated login attacks.
- Monitor for credential stuffing and brute-force attack patterns.
- Encourage users to create strong and unique passwords.

Expected Benefit

These measures help prevent account takeover attacks and improve overall account security.

Secure Staging and Development Environments

The discovery of a staging administrative portal highlights the importance of protecting non-production systems.

Recommendations

- Restrict staging environment access to authorized personnel only.
- Implement IP allowlisting or VPN-based access controls.
- Remove unnecessary public exposure of testing environments.
- Regularly audit staging systems for security misconfigurations.
- Ensure production data is never used in testing environments.

Expected Benefit

Properly securing staging environments reduces the risk of information leakage and unauthorized access.

Manage Publicly Accessible Documents

Public documents should be reviewed regularly to ensure sensitive information is not unintentionally disclosed.

Recommendations

- Remove unnecessary metadata from PDF documents before publication.
- Review documents for sensitive information before public release.
- Establish document classification and publication procedures.
- Conduct periodic audits of publicly accessible files.

Expected Benefit

These actions reduce the amount of information available to attackers during reconnaissance.

Strengthen Protection Against Social Engineering

Publicly available contact information can be exploited by attackers through phishing and impersonation attacks.

Recommendations

- Conduct regular cybersecurity awareness training for employees.
- Educate customer support staff on social engineering tactics.
- Implement email security solutions such as DMARC, SPF, and DKIM.
- Establish procedures for verifying customer identities before disclosing information.

Expected Benefit

Improved awareness and verification procedures help reduce the likelihood of successful phishing and impersonation attacks.

Monitor and Secure All Subdomains

Multiple Konga-related subdomains were identified during reconnaissance.

Recommendations

- Maintain an up-to-date inventory of all subdomains and digital assets.
- Perform regular vulnerability assessments and penetration testing.
- Remove or decommission unused subdomains.
- Monitor DNS records for unauthorized changes.
- Implement Web Application Firewalls (WAFs) on public-facing applications.

Expected Benefit

These measures reduce the attack surface and improve visibility across Konga's online infrastructure.

Strengthen API Security

API-related resources were identified and should be protected using industry best practices.

Recommendations

- Implement strong authentication and authorization controls for APIs.
- Apply rate limiting to prevent abuse.
- Encrypt data in transit using HTTPS/TLS.
- Conduct regular API security testing.
- Monitor API activity for suspicious behavior.
- Follow OWASP API Security Top 10 guidelines.

Expected Benefit

Enhanced API security reduces the risk of unauthorized access, data exposure, and service abuse.

Continuous Security Monitoring

Cybersecurity is an ongoing process that requires continuous monitoring and improvement.

Recommendations

- Deploy Security Information and Event Management (SIEM) solutions.
- Monitor logs from web servers, APIs, and authentication systems.
- Establish an incident response plan.
- Conduct periodic security audits and risk assessments.
- Implement threat intelligence monitoring to identify emerging threats.

Expected Benefit

Continuous monitoring enables faster detection and response to potential security incidents.

Conclusion

The Google dorking assessment demonstrated that Konga has a broad online presence consisting of customer portals, merchant platforms, APIs, support systems, documents, and multiple subdomains. Although no direct vulnerabilities were identified during this reconnaissance exercise, the publicly available information could assist threat actors in conducting further reconnaissance or social engineering attacks.

By implementing the recommendations outlined in this report, Konga can strengthen its security posture, reduce its attack surface, and improve protection against both current and emerging cyber threats. The assessment highlights the importance of proactive security measures, continuous monitoring, and regular reviews of publicly accessible resources to maintain a secure digital environment.

11. PLATEAU STATE ASSESSMENT

11.1 SECTOR – AVIATION – Plateau State, Nigeria

Organization Name:

[Federal Airports Authority of Nigeria \(FAAN\)](#)

Domain Name:

FAAN.gov.ng

1. Organization Profile & Reconnaissance (OSINT) – FAAN Nigeria

Organization Overview

FAAN is the government agency responsible for managing Nigerian airports, ensuring aviation safety, airport security, passenger services, and infrastructure development across domestic and international airports.

Digital Footprint Overview (OSINT Summary)

Based on OSINT tools (Google Dorking, Netcraft, BuiltWith, and WhatCMS), FAAN operates a **large multi-service digital ecosystem**:

Key Observed Digital Assets:

- <https://faan.gov.ng> (Main public portal)
- <https://aps.faan.gov.ng> (Application/portal system)
- <https://trainingschool.faan.gov.ng> (Aviation training systems)
- <https://hmo.faan.gov.ng> (internal service modules)
- <https://pebec.faan.gov.ng> (complaints / reporting portal)
- Multiple PDF document repositories under /uploads/

Observation:

FAAN has a **distributed web architecture with multiple subdomains**, indicating a modular government IT structure.

Infrastructure & Hosting Intelligence (Netcraft Findings)

From Netcraft analysis:

- **Hosting Provider:** GoDaddy / Host Europe GmbH
- **IP Address:** 92.205.188.234
- **ASN:** AS21499

- **DNS Provider:** domaincontrol.com (GoDaddy DNS)
- **CDN Usage:** None explicitly confirmed (no Cloudflare shielding detected in Netcraft)
- **Server Location:** Germany (DE-GODADDY infrastructure)

Key Observation:

FAAN.gov.ng is hosted on **commercial foreign infrastructure (GoDaddy/Host Europe)** rather than local Nigerian hosting.

Web Technology Stack (BuiltWith + WhatCMS + Netcraft)

CMS & Backend:

- WordPress (Self-hosted CMS)
- PHP backend
- MySQL database
- Elementor page builder

Frontend Technologies:

- JavaScript (jQuery, AJAX)
- Bootstrap framework
- Font Awesome icons
- HTML5 + CSS3

Security & Web Controls:

- HTTP Security Headers:
 - HSTS (Strict Transport Security)
 - X-Frame-Options
 - CSP (Content Security Policy)
 - X-Content-Type-Options

Tracking & Analytics:

- Google CDN / Google services
- Minimal third-party trackers detected

Observation:

The platform is **WordPress-driven**, which introduces a known category of risks (plugin vulnerabilities, misconfiguration risks, CMS exploitation surface).

Attack Surface Mapping

Identified Public Attack Surface:

- Primary domain: faan.gov.ng
- Multiple subdomains:
 - aps.faan.gov.ng
 - hmo.faan.gov.ng
 - trainingschool.faan.gov.ng
 - psc.faan.gov.ng
 - fnac.faan.gov.ng

Exposed Entry Points:

- Login pages (WordPress-based and custom portals)
- Public PDFs (/uploads/)
- API-like endpoints (WordPress + PHP modules)
- Error pages (404 handling observed)
- Government service forms (data submission interfaces)

Key Observation:

FAAN has a **large distributed attack surface typical of government enterprise systems.**

Security Exposure Indicators (OSINT-Based)

Observed indicators:

- WordPress CMS detected - known frequent attack target
- Multiple subdomains - increased misconfiguration risk
- Public document directories (/uploads/)
- Mixed security headers (present but not uniformly enforced)
- External hosting dependency (GoDaddy infrastructure)
- Email security enabled (SPF + DMARC present)

Positive Security Signals:

- DMARC policy configured (quarantine mode)
- SPF records active
- HTTPS enforcement implied via headers

Data Protection Considerations

- Email authentication is partially enforced (SPF + DMARC)
- No visible direct sensitive data exposure in OSINT phase
- Public portals do not appear to expose raw database or admin interfaces

However:

- Public WordPress files and uploads may still enable **reconnaissance enumeration risk**

Summary of Reconnaissance Findings

The OSINT investigation of FAAN Nigeria reveals:

Key Strengths:

- Structured multi-subdomain architecture
- Use of standard web security headers
- Email authentication controls (SPF/DMARC)
- CDN and modern frontend frameworks

Key Risks:

- WordPress CMS exposure increases attack surface
- Multiple subdomains increase misconfiguration risk
- External hosting (GoDaddy Germany) introduces dependency risk
- Public document repositories increase reconnaissance exposure

Overall Assessment:

FAAN operates a **moderately secure but highly exposed government digital ecosystem**, where risk is driven more by **architecture complexity and CMS usage** than by direct CVE-level exploitation.

2. Vulnerability & Weakness Analysis – FAAN Nigeria

Framework Reference

The vulnerabilities and security weaknesses identified in this assessment were analyzed using standard cybersecurity frameworks and industry references, including:

- Common Vulnerabilities and Exposures (CVE) – for known software vulnerabilities (if applicable)
- Common Weakness Enumeration (CWE) – for identifying structural security weaknesses
- OWASP Top 10 (2021/2025 concepts) – for web application risk classification
- OWASP API Security Top 10 – for API-related risks
- NIST Cybersecurity Framework – for risk interpretation and categorization

- OSINT tools including Netcraft, BuiltWith, WhatCMS, and Google Dorking

Findings

This assessment did not identify any confirmed software version exposure that could be mapped to specific CVEs.

Therefore, the findings in this section are based on:

- Publicly available infrastructure information
- Attack surface analysis
- Observed web technologies
- OSINT recon results from tools used

All vulnerabilities listed are **security weaknesses inferred from exposure and architecture**, not confirmed exploits.

Identified Security Weaknesses

Large and Distributed Attack Surface

Observation

FAAN operates multiple public-facing subdomains and services, including:

- faan.gov.ng
- aps.faan.gov.ng
- hmo.faan.gov.ng
- trainingschool.faan.gov.ng
- psc.faan.gov.ng

Each of these services provides different functions such as applications, training, reporting, and administration.

Weakness Description

The presence of many interconnected systems increases the external attack surface. Each subdomain may have different configurations, security settings, and technologies.

Security Mapping

- OWASP Top 10: A05 – Security Misconfiguration
- OWASP Top 10: A04 – Insecure Design

Risk Impact

- More entry points for attackers
- Higher chance of misconfiguration in one or more services

- Difficult to maintain consistent security across all platforms

WordPress CMS Exposure

Observation

Netcraft and WhatCMS analysis shows that FAAN uses:

- WordPress CMS
- PHP backend
- MySQL database
- Elementor page builder and other plugins

Weakness Description

WordPress is widely used and secure when properly maintained, but it is also a common target for attackers due to plugin vulnerabilities and misconfiguration risks.

CWE Mapping

- CWE-200: Information Exposure
- CWE-1392: Weak Configuration

OWASP Mapping

- A06: Vulnerable and Outdated Components
- A05: Security Misconfiguration

Risk Impact

- Plugin-based vulnerabilities if not updated
- Risk of unauthorized access through weak configurations
- Potential exploitation of known CMS weaknesses

Authentication Endpoint Exposure

Observation

Multiple authentication-related endpoints exist across different FAAN services, such as:

- Login pages
- Registration forms
- Account portals

Weakness Description

Having multiple authentication entry points increases exposure to credential-based attacks.

CWE Mapping

- CWE-287: Improper Authentication
- CWE-307: Improper Restriction of Excessive Authentication Attempts

OWASP Mapping

- A07: Identification and Authentication Failures

Risk Impact

- Brute force login attempts
- Credential stuffing attacks
- Phishing of login pages targeting users

Information Disclosure from Public Resources

Observation

Google dorking and OSINT analysis revealed publicly accessible:

- PDF documents (policies, manuals, acts)
- Business application forms
- Upload directories under /uploads/
- Service-related documents

Weakness Description

Some internal or semi-sensitive documents are publicly accessible, which increases information exposure.

CWE Mapping

- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

OWASP Mapping

- A01: Broken Access Control
- A05: Security Misconfiguration

Risk Impact

- Easier reconnaissance for attackers
- Exposure of internal processes and structure
- Increased risk of targeted phishing attacks

Third-Party Dependencies (Supply Chain Risk)

Observation

The platform uses several external services and libraries including:

- Google CDN services

- jQuery libraries
- Bootstrap framework
- External JavaScript and tracking services

Weakness Description

External dependencies introduce risk because their security is outside the direct control of FAAN.

CWE Mapping

- CWE-829: Inclusion of Functionality from Untrusted Control Sphere

OWASP Mapping

- A08: Software and Data Integrity Failures

Risk Impact

- Risk from compromised third-party scripts
- Data exposure through external analytics tools
- Dependency on external service security posture

Email Security Configuration

Observation

Netcraft analysis shows:

- SPF record is active
- DMARC policy is set to quarantine

Weakness Description

Although email authentication is enabled, the policy is not fully strict (not reject mode).

CWE Mapping

- CWE-290: Authentication Bypass by Spoofing (email spoofing context)

OWASP Mapping

- A01: Broken Access Control (indirect phishing exposure)

Risk Impact

- Possible phishing attacks using FAAN domain
- Email spoofing attempts
- Reduced protection compared to full DMARC enforcement

Security Headers Implementation

Observation

FAAN implements several security headers such as:

- HSTS (Strict Transport Security)
- X-Frame-Options
- Content Security Policy (CSP)
- X-Content-Type-Options

Weakness Description

Security headers are present but may not be consistently enforced across all subdomains.

CWE Mapping

- CWE-693: Protection Mechanism Failure

Risk Impact

- Some services may still be vulnerable due to inconsistent configuration
- Attack surface varies across subdomains

Summary of Vulnerability & Weakness Analysis

The analysis shows that FAAN Nigeria does not have directly identifiable CVE-level vulnerabilities from passive OSINT tools. However, several structural security weaknesses were identified.

Key Findings:

- Multiple subdomains increase attack surface exposure
- WordPress CMS introduces common security risks if not fully hardened
- Multiple authentication points increase risk of credential-based attacks
- Public documents and uploads increase information exposure
- Third-party dependencies introduce supply chain risks
- Email security is partially implemented but not at maximum strictness

Overall Conclusion:

FAAN's security posture is generally stable, but the main risks come from system complexity, distributed architecture, and configuration consistency rather than direct software vulnerabilities.

3. Threat Impact & Exploitability Scenario – FAAN Nigeria

Overview

This section evaluates the likelihood and impact of the identified security weaknesses in Section 2. The assessment is based on OSINT findings, system exposure level, and common industry risk patterns.

Risk levels are categorized using:

- **Likelihood (Low / Medium / High)** – chance of exploitation
- **Impact (Low / Medium / High)** – potential damage if exploited
- **Overall Risk** – combined assessment of both factors

Risk Evaluation Summary

No.	Identified Weakness	Likelihood	Impact	Overall Risk
1	Large and Distributed Attack Surface	High	Medium	High
2	WordPress CMS Exposure	Medium	High	High
3	Authentication Endpoint Exposure	High	High	High
4	Information Disclosure (Public Documents)	High	Medium	High
5	Third-Party Dependency Exposure	Medium	Medium	Medium
6	Email Security (SPF/DMARC Partial Enforcement)	Medium	High	High
7	Security Header Inconsistency	Low	Medium	Medium

Explanation of Risk Ratings:

High Risk Items

Attack Surface Expansion

The presence of many subdomains increases the number of entry points. This makes it easier for attackers to find weak or misconfigured services.

- Likelihood: High (many entry points available)
- Impact: Medium (depends on exposed service)

WordPress CMS Exposure

WordPress is widely used and often targeted when not fully updated or properly secured.

- Likelihood: Medium (requires specific exploitation conditions)
- Impact: High (CMS compromise can affect entire website)

Authentication Exposure

Multiple login pages increase exposure to brute-force and phishing attacks.

- Likelihood: High (login pages are publicly accessible)
- Impact: High (can lead to account takeover)

Information Disclosure

Publicly available documents and files can be used by attackers for reconnaissance.

- Likelihood: High (documents are openly accessible)
- Impact: Medium (supports further attacks but not direct compromise)

Email Security Weakness

DMARC is set to quarantine instead of reject, which allows some phishing risk.

- Likelihood: Medium
- Impact: High (can lead to impersonation and phishing attacks)

Medium Risk Items

Third-Party Dependencies

External scripts and services introduce indirect risk depending on external security posture.

- Likelihood: Medium
- Impact: Medium

Security Header Inconsistency

Security headers exist but may not be applied uniformly across all subdomains.

- Likelihood: Low
- Impact: Medium

Overall Risk Statement

Based on the analysis, FAAN Nigeria's digital infrastructure shows a **high overall risk level**, mainly due to:

- Large attack surface
- Multiple authentication endpoints
- Public information exposure
- CMS-based architecture

However, no direct critical exploit or CVE-level vulnerability was identified from OSINT tools.

Final Risk Classification

Overall Risk Level: HIGH

Reason:

The combination of multiple exposed services and authentication points increases the probability of attack, even though no direct exploit was confirmed.

4. Mitigation & Technical Remediation Plan – FAAN Nigeria

Overview

This section provides recommended security improvements based on the weaknesses identified in Sections 2 and 3.

The recommendations are divided into:

- **Immediate Mitigations (short-term fixes)**
- **Long-Term Remediation (structural improvements)**

The aim is to reduce exposure, improve configuration security, and strengthen overall system resilience.

Attack Surface Reduction**Observed Weakness**

FAAN operates multiple subdomains and services, increasing the overall attack surface.

Immediate Mitigation

- Disable or restrict unused or inactive subdomains
- Close unnecessary public-facing endpoints
- Apply firewall rules to restrict internal services

Long-Term Remediation

- Implement centralized API gateway for all services
- Apply Zero Trust Architecture (ZTA) principles
- Conduct regular attack surface reviews

Authentication Security Improvement**Observed Weakness**

Multiple login and authentication portals across different services.

Immediate Mitigation

- Enable CAPTCHA on login pages
- Implement account lockout after repeated failed attempts
- Enforce strong password policy

Long-Term Remediation

- Deploy Multi-Factor Authentication (MFA) across all systems
- Use centralized identity management (Single Sign-On)
- Implement risk-based authentication (adaptive login security)

CMS (WordPress) Hardening

Observed Weakness

FAAN uses WordPress CMS with plugins and third-party extensions.

Immediate Mitigation

- Update WordPress core, themes, and plugins regularly
- Remove unused plugins and themes
- Restrict admin access using IP filtering

Long-Term Remediation

- Implement Web Application Firewall (WAF)
- Use hardened WordPress security configuration
- Conduct regular CMS security audits

Information Exposure Control

Observed Weakness

Publicly accessible documents and upload directories.

Immediate Mitigation

- Restrict access to sensitive PDF and internal documents
- Disable directory listing on web servers
- Review /uploads/ directory permissions

Long-Term Remediation

- Implement access control policies for all document storage
- Separate public and internal document storage systems
- Apply data classification rules (public vs internal data separation)

Third-Party Dependency Management

Observed Weakness

Use of external scripts such as Google CDN, jQuery, and Bootstrap libraries.

Immediate Mitigation

- Remove unused third-party scripts
- Monitor external script sources regularly
- Use Content Security Policy (CSP) to control script execution

Long-Term Remediation

- Implement third-party vendor risk management policy
- Use Subresource Integrity (SRI) for external scripts
- Maintain approved list of trusted external services

Email Security Strengthening

Observed Weakness

DMARC policy is set to “quarantine” instead of “reject”.

Immediate Mitigation

- Monitor phishing attempts using FAAN domain
- Review SPF and DMARC configuration

Long-Term Remediation

- Upgrade DMARC policy from quarantine to reject
- Implement DMARC reporting analysis system
- Strengthen email authentication monitoring

Security Monitoring & Incident Response

Observed Weakness

Distributed systems make monitoring more complex.

Immediate Mitigation

- Enable logging on all authentication and API systems
- Set up alerts for unusual login activity

Long-Term Remediation

- Deploy centralized SIEM system
- Establish Security Operations Center (SOC) monitoring
- Integrate threat intelligence feeds for early detection

Summary of Recommendations

The main security improvements required for FAAN Nigeria include:

- Reducing attack surface complexity
- Strengthening authentication systems
- Hardening WordPress CMS environment
- Controlling public data exposure
- Improving email security policies
- Enhancing monitoring and incident response capability

Conclusion

Implementing these recommendations will significantly reduce FAAN's exposure to common web-based attacks and improve overall system security posture.

12. KADUNA STATE ASSESSMENT

12.1 SECTOR – INSURANCE – Kaduna State, Nigeria

Organization Name:

NICON Insurance Limited

Domain Name:

niconinsurance.com.ng

1. Organization Profile & Reconnaissance (OSINT) - NICON

Digital Footprint Overview

NICON Insurance Limited operates as a major Nigerian insurance provider with a publicly accessible digital presence under:

- Primary Domain: niconinsurance.com.ng
- Login Portal: portal.niconinsurance.com.ng
- IP Address: 216.194.167.27
- Registrar: GO54 Limited (WhoGoHost)
- Nameservers: InMotion Hosting infrastructure

- Domain Age: Created 2009 (long-term operational maturity)

Observation

The domain reflects a stable and long-standing enterprise system, indicating mature business operations but also legacy infrastructure exposure.

Infrastructure & Hosting Intelligence

Analysis of DNS and OSINT data shows:

- Hosting Provider: InMotion Hosting (United States)
- Server Location: United States
- Web Server: Apache HTTP Server
- CMS: WordPress 6.x
- Database: MySQL
- Backend Language: PHP
- SSL: Let's Encrypt (HTTPS enforced on main domain)

Observation

The infrastructure is externally hosted and cloud-managed, reducing local infrastructure control but improving scalability.

Web Technology Stack

Identified technologies include:

- WordPress CMS (v6.x)
- PHP + MySQL backend
- Apache HTTP Server
- WordPress plugins (Contact Form 7, User Registration tools)
- Google Fonts API
- Font Awesome
- jQuery and UI libraries

Observation

The system relies heavily on WordPress plugins, increasing dependency risk from third-party components.

Attack Surface Mapping

1. Public Web Pages

- Homepage and product pages
- About Us / Contact / Careers
- Claims processing pages
- FAQ sections

2. Document Exposure (IMPORTANT FINDING)

From Google Dorking:

- /uploads/2019/01/CLAIMS-SETTLEMENT-PROCESS-FOR-WEBSITE-PUBLICATION.pdf
- BOARD-RESOLUTION.docx

3. Authentication Systems

- Login portal:
<https://www.portal.niconinsurance.com.ng/auth/login>
- Forgot password endpoint exists

4. Subdomains Identified

- portal.niconinsurance.com.ng
- www.niconinsurance.com.ng

Observation Summary

The attack surface includes:

- Public insurance service pages
- Login portal system
- Document upload directories
- WordPress CMS backend structure
- External hosting environment

2. Vulnerability & Weakness Analysis - NICON

Framework Reference

- CVE (Common Vulnerabilities and Exposures)
- CWE (Common Weakness Enumeration)
- OWASP Top 10:2025
- API Security Guidelines

1. Public Document Exposure (Information Disclosure Risk)

Description

Google dorking revealed publicly accessible PDF and DOCX files in upload directories.

Security Mapping

- CWE-200: Exposure of Sensitive Information
- OWASP 2025: A01 – Broken Access Control
- OWASP 2025: A06 – Insecure Design

Risk

- Sensitive internal documents exposed (e.g., board resolution files)
- Supports attacker reconnaissance
- May reveal internal business structure

2. Authentication Portal Exposure

Description

A dedicated login portal exists:

- portal.niconinsurance.com.ng/auth/login

Security Mapping

- CWE-307: Improper Restriction of Authentication Attempts
- OWASP 2025: A07 – Authentication Failures

Risk

- Brute-force login attempts
- Credential stuffing attacks
- Phishing impersonation risk

3. WordPress CMS Dependency Risk

Description

The system uses WordPress 6.x with multiple plugins.

Security Mapping

- CWE-829: Supply Chain Dependency Risk
- OWASP 2025: A03 – Software Supply Chain Failures

Risk

- Plugin vulnerabilities

- Delayed patching exposure
- Theme exploitation risks

4. Apache Web Server Exposure

Description

Apache HTTP Server detected (version not confirmed as patched).

Security Mapping

- CWE-400: Resource Exhaustion
- OWASP 2025: A02 – Security Misconfiguration

Risk

- Misconfiguration vulnerabilities
- Denial-of-service exposure
- Known CVE exposure if unpatched

5. Operational Weakness (Email Security Gap)

Description

No SPF/DMARC record detected (from Netcraft analysis)

Security Mapping

- CWE-290: Authentication Bypass by Spoofing
- OWASP 2025: A07 – Authentication Failures

Risk

- Email spoofing attacks
- Phishing impersonation of insurance domain
- Fraudulent claims communication

Summary of Weaknesses

- Public document exposure
- Authentication portal exposure
- CMS/plugin dependency risks
- Missing email authentication controls
- Potential outdated server configuration

3. Threat Impact & Exploitability Scenario - NICON

Primary Risk: Public Document Exposure + Login Portal

Attack Scenario

1. Attacker performs OSINT using Google dorking
2. Discovers internal PDF and DOCX documents
3. Uses information for social engineering or phishing
4. Targets login portal with credential stuffing
5. Attempts account takeover of user or staff accounts

CVSS (Estimated Scenario-Based)

- Score: 6.5 – Medium

Reason: Requires external access but enables meaningful reconnaissance

EPSS (Likelihood Estimate)

- Medium–High probability due to:
 - Public exposure of documents
 - Active login portal
 - Insurance sector targeting (high-value data)

Business Impact

Operational Impact

- Claims processing disruption
- Account login compromise
- Service downtime risk

Financial Impact

- Fraudulent insurance claims
- Recovery and incident response costs

Reputational Impact

- Loss of customer trust
- Brand damage in financial sector

Regulatory Impact

- Nigeria Data Protection Act (NDPA) violations if data exposed

4. Mitigation & Technical Remediation Plan - NICON

Immediate Mitigation

- Remove or restrict access to /uploads/ directory
- Disable public indexing of internal documents
- Enable login rate limiting and CAPTCHA
- Review WordPress plugins for vulnerabilities
- Enable SPF and DMARC email policies

Permanent Remediation

- Implement access control for document storage
- Migrate to secure document management system
- Enforce Multi-Factor Authentication (MFA)
- Regular WordPress patch management program
- Deploy Web Application Firewall (WAF)
- Implement email authentication (SPF, DKIM, DMARC)

Verification Strategy

- Re-run Google dorking to confirm document removal
- Test login brute-force protection
- Validate SPF/DMARC records
- Confirm WordPress version updates
- Perform CMS vulnerability scan

Conclusion

The assessment of NICON Insurance Limited reveals a moderately exposed digital infrastructure primarily driven by public document indexing and authentication portal exposure. While no direct critical vulnerabilities were identified, the presence of publicly accessible internal documents and missing email authentication controls increases the organization's susceptibility to phishing, credential attacks, and information disclosure risks. Strengthening access controls, securing document repositories, and implementing email authentication mechanisms will significantly improve the overall security posture.

13. KEBBI STATE ASSESSMENT

13.1 SECTOR – EDUCATION – Kebbi State, Nigeria

Organization Name: Kebbi State University of Science and Technology, Aliero (KSUSTA)

Current Name: Abdullahi Fodio University of Science and Technology, Aliero (AFUSTA)

Website: ksusta.edu.ng

Sector: Education (Public University)

Location: Aliero, Kebbi State, Nigeria

Type: Public University

1. Organization Profile & Reconnaissance (OSINT) - KSUSTA (AFUSTA)

Organization Overview

KSUSTA (now AFUSTA) is a state-owned tertiary institution that provides undergraduate, postgraduate, research, and administrative academic services. The university operates multiple web-based systems supporting admissions, student registration, staff services, academic publications, and institutional communication.

The institution maintains a publicly accessible digital infrastructure that supports students, staff, and prospective applicants, making it an important educational asset within Kebbi State.

Target Identification

Item	Details
Organization Name	Kebbi State University of Science and Technology (KSUSTA) / AFUSTA
Sector	Education (Public University)
Location	Aliero, Kebbi State, Nigeria
Primary Domain	ksusta.edu.ng
IP Address	67.43.4.85
Hosting Provider	Liquid Web LLC
Hosting Country	United States
Web Server	Apache HTTP Server
Reverse DNS	host2.flexisaf.com
Backend Language	PHP
CMS	WordPress 6.9
Registrar	GO54 Limited (WhoGoHost)
Domain Creation Date	13 May 2009
Last Updated	15 July 2025
Expiry Date	31 July 2026
Nameservers	ns.liquidweb.com, ns1.liquidweb.com
DNSSEC	Enabled

Digital Footprint

Primary Web Assets

- <https://ksusta.edu.ng> (Main University Website)
- Admissions Portal
- Undergraduate Student Portal
- Postgraduate Student Portal
- Undergraduate Staff Portal
- Postgraduate Staff Portal

- Downloads Repository
- TETFund Portal

Identified Technologies

OSINT technology fingerprinting identified:

- Apache HTTP Server
- WordPress 6.9 CMS
- WooCommerce
- Elementor Pro
- Essential Addons for Elementor
- PHP
- OpenResty 1.29.2.3
- jQuery 3.7.1
- Google Workspace (Google Apps)
- Let's Encrypt SSL Certificates

Observed Functional Systems

The following operational systems were identified:

- Undergraduate student portal
- Postgraduate student portal
- Staff portal systems
- Admissions management platform
- Online screening platform
- Download repository
- Academic information system
- TETFund information portal

Attack Surface Mapping

Analysis of publicly available information revealed several internet-facing assets that may expand the university's attack surface.

1. Authentication Systems

Google dorking revealed multiple authentication-related systems including:

- UG Student Portal
- PG Student Portal
- UG Staff Portal
- PG Staff Portal
- Admissions and Screening Systems

Potential Exposure:

- Login interfaces
- Password reset mechanisms
- User authentication endpoints

2. Academic Document Exposure

Publicly indexed PDF documents were discovered through search engine reconnaissance.

Examples include:

- 2025 Admission Cut-Off Marks
- Post-UTME Registration Guidelines
- Academic Bulletins
- Scholarship Announcements
- TETFund-related Publications

Potential Exposure:

- Institutional information disclosure
- Internal process documentation
- Administrative communications

3. WordPress Administrative Surface

Technology analysis identified WordPress 6.9 and several plugins.

Potentially exposed components include:

- wp-admin
- wp-content/uploads
- Plugin directories
- Theme resources

Potential Exposure:

- CMS management interfaces
- Plugin vulnerabilities
- Administrative endpoints

4. Multiple Portal Infrastructure

The university operates several web services supporting different academic functions.

Observed Systems:

- Student portals
- Staff portals
- Admissions platform
- Download repositories
- TETFund pages

Potential Exposure:

- Increased attack surface
- Authentication management complexity
- Greater dependency on centralized security controls

5. Email Infrastructure Exposure

Netcraft analysis revealed:

SPF Record: Not Detected

DMARC Record: Not Detected

Potential Exposure:

- Email spoofing
- Phishing campaigns
- Domain impersonation attacks

OSINT Findings Summary

The OSINT assessment identified a moderately exposed educational infrastructure comprising:

- Public-facing university website
- Multiple student and staff authentication portals
- WordPress-based content management system
- Publicly indexed academic documents
- Cloud-hosted infrastructure
- Missing SPF and DMARC email authentication controls
- Several interconnected web applications supporting academic operations

These findings indicate that KSUSTA/AFUSTA maintains a significant online presence that supports academic service delivery but also increases exposure to web application, authentication, and information disclosure risks, warranting further vulnerability analysis and security review.

2. Vulnerability & Weakness Analysis – KSUSTA (AFUSTA)

Framework References

- CVE (Common Vulnerabilities and Exposures)
- CWE (Common Weakness Enumeration)
- OWASP Top 10 (2025)
- NIST Cybersecurity Framework

1. Missing Email Authentication Controls

Description

Netcraft analysis revealed that the domain does not have publicly visible SPF and DMARC records configured. These email authentication mechanisms help prevent unauthorized parties from sending emails that appear to originate from the university domain.

Security Mapping

- CWE-290: Authentication Bypass by Spoofing
- OWASP Top 10 2025: A07 – Authentication Failures

Potential Risk

- Email spoofing attacks
- Phishing campaigns targeting students and staff
- Fraudulent admission or payment-related emails
- Reputational damage to the institution

2. Public Authentication Portal Exposure

Description

OSINT and Google dorking identified multiple publicly accessible authentication systems including:

- Undergraduate Student Portal
- Postgraduate Student Portal
- Undergraduate Staff Portal
- Postgraduate Staff Portal
- Admissions and Screening Systems

These portals increase the number of publicly exposed authentication endpoints.

Security Mapping

- CWE-307: Improper Restriction of Excessive Authentication Attempts
- CWE-287: Improper Authentication
- OWASP Top 10 2025: A07 – Authentication Failures

Potential Risk

- Brute-force attacks
- Credential stuffing attacks

- Unauthorized account access
- Student or staff account compromise

3. Academic Document Exposure

Description

Google dorking identified multiple publicly indexed PDF documents hosted within the university website, including admission notices, bulletins, registration guidelines, and institutional publications.

Examples include:

- Admission cut-off mark documents
- Post-UTME registration guides
- Academic bulletins
- Scholarship announcements

Security Mapping

- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
- OWASP Top 10 2025: A01 – Broken Access Control

Potential Risk

- Information gathering by attackers
- Institutional profiling
- Social engineering attacks
- Discovery of internal operational processes

4. WordPress CMS and Plugin Dependency Risk

Description

Technology fingerprinting identified WordPress 6.9 together with several third-party plugins and extensions, including:

- Elementor Pro
- Essential Addons for Elementor
- WooCommerce

The security of the platform depends heavily on timely updates and secure plugin management.

Security Mapping

- CWE-1104: Use of Unmaintained Third-Party Components
- OWASP Top 10 2025: A03 – Software Supply Chain Failures

Potential Risk

- Plugin vulnerabilities
- Third-party component compromise
- Website defacement
- Unauthorized administrative access

5. PHP-Based Application Security Risk

Description

The university's web applications operate on a PHP backend supporting admissions, portals, and content management services.

PHP-based applications commonly face security challenges when secure coding controls are not consistently implemented.

Security Mapping

- CWE-20: Improper Input Validation
- CWE-79: Cross-Site Scripting (XSS)
- CWE-89: SQL Injection
- OWASP Top 10 2025: A05 – Injection

Potential Risk

- Data disclosure
- Unauthorized database access
- Session hijacking
- Manipulation of application data

6. Multiple Portal and Service Attack Surface

Description

The university maintains several independent web services including student portals, staff portals, admissions systems, downloads repositories, and institutional information pages.

A larger digital footprint increases the complexity of maintaining consistent security controls across all systems.

Security Mapping

- CWE-16: Configuration
- OWASP Top 10 2025: A02 – Security Misconfiguration

Potential Risk

- Inconsistent security configurations
- Forgotten or outdated services
- Increased vulnerability management complexity
- Expanded attack opportunities

7. Apache Web Server Exposure

Description

Technology analysis identified Apache HTTP Server as part of the university's web infrastructure. If the server is not regularly patched and maintained, it may be exposed to known vulnerabilities affecting Apache web services.

Relevant vulnerabilities historically associated with Apache HTTP Server 2.4.41 include:

- CVE-2020-1934
- CVE-2020-1927
- CVE-2020-13950

Note: The presence of these CVEs does not confirm exploitation or vulnerability. They are referenced because they affect Apache 2.4.41 environments and should be reviewed if that version is deployed.

Security Mapping

- CWE-1104: Use of Unmaintained Third-Party Components
- OWASP Top 10 2021: A06 – Vulnerable and Outdated Components

Potential Risk

- Denial-of-Service attacks
- Information disclosure

- Service instability
- Increased attack surface

Summary of Weaknesses

The assessment identified the following potential security concerns:

- Missing SPF and DMARC email authentication controls
- Multiple publicly exposed authentication portals
- Publicly indexed academic documents
- WordPress plugin and supply-chain dependency risks
- PHP application security risks
- Expanded attack surface through multiple portal systems
- Potential Apache server exposure if legacy versions remain deployed

These findings indicate that while KSUSTA/AFUSTA maintains a functional digital infrastructure for academic operations, improvements in authentication security, email protection, software maintenance, and attack surface management would further strengthen the institution's cybersecurity posture.

3. Threat Impact & Exploitability Scenario – KSUSTA (AFUSTA)

Primary Risk: Public Authentication Portals and Missing Email Authentication Controls

Attack Scenario

A potential attacker may leverage publicly available information gathered through OSINT and search engine reconnaissance to identify exposed university systems and authentication portals.

A possible attack path could be:

1. The attacker performs reconnaissance using Google dorking and public search engines.
2. Publicly indexed documents are collected to understand university operations, admissions processes, staff structures, and student services.
3. The attacker discovers multiple authentication systems including:
 - Undergraduate Student Portal
 - Postgraduate Student Portal
 - Undergraduate Staff Portal
 - Postgraduate Staff Portal

4. Due to the absence of SPF and DMARC protections, the attacker creates spoofed emails impersonating the university.
5. Phishing emails are sent to students or staff requesting password resets, admission verification, or account updates.
6. Stolen credentials may then be used to attempt unauthorized access to university portals.
7. If successful, the attacker could gain access to student records, staff information, academic resources, or administrative systems.

CVSS Assessment (Estimated)

Authentication Portal Exposure

CVSS v3.1 Score: 6.5 (Medium)

Vector: AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:L/A:L

Justification

- Publicly accessible over the internet
- Low technical complexity required
- Exploitation may require user interaction
- Potential exposure of sensitive academic information

EPSS Assessment (Estimated)

EPSS Likelihood: Medium

Reasoning

The likelihood of exploitation increases due to:

- Publicly accessible login portals
- Large student population
- Frequent use of email communications
- Educational institutions being common phishing targets

Business Impact Analysis

Operational Impact

Potential consequences include:

- Disruption of student portal services
- Unauthorized access to academic resources
- Interruption of admission and registration activities
- Increased workload for ICT and support teams

Academic Impact

Potential consequences include:

- Unauthorized access to student records
- Manipulation of academic information
- Exposure of institutional documents
- Reduced confidence in online learning and administrative systems

Financial Impact

Potential consequences include:

- Incident response costs
- System recovery expenses
- Additional cybersecurity investments
- Potential loss of revenue from disrupted admission processes

Reputational Impact

Potential consequences include:

- Loss of trust among students and parents
- Negative media attention
- Reduced confidence in university digital services
- Damage to institutional reputation

Regulatory Impact

The university processes significant amounts of personal information including:

- Student records
- Staff records
- Admission information
- Academic documentation

A successful compromise involving personal data could result in non-compliance concerns under the Nigeria Data Protection Act (NDPA).

Potential consequences include:

- Regulatory investigations
- Compliance review requirements
- Data protection remediation obligations

Risk Rating Summary

Risk Area	Impact Level
Authentication Portal Exposure	Medium
Email Spoofing & Phishing	Medium-High
Information Disclosure	Medium
Academic Service Disruption	Medium
NDPA Compliance Risk	Medium
Reputational Damage	Medium-High

Conclusion

The primary cybersecurity concerns identified for KSUSTA (AFUSTA) stem from its publicly exposed authentication systems, publicly accessible institutional documents, and the absence of SPF and DMARC email authentication controls. While no active compromise was identified during this assessment, these weaknesses could be leveraged by attackers to conduct phishing campaigns, credential theft, unauthorized access attempts, and information-gathering activities. Strengthening authentication security, improving email protection mechanisms, and reducing unnecessary information exposure would significantly enhance the university's overall cybersecurity posture.

4. Mitigation & Technical Remediation Plan – KSUSTA

Immediate Mitigation

- Review and restrict public access to sensitive document repositories and upload directories.
- Disable directory listing and indexing where not required.
- Implement login rate limiting and account lockout policies on student and staff portals.
- Enforce strong password requirements across all authentication systems.
- Enable HTTPS redirection across all university web services and portals.
- Configure and deploy SPF records to reduce email spoofing risks.
- Implement DMARC policies to strengthen email authentication and monitoring.
- Review WordPress plugins, themes, and third-party components for known vulnerabilities.
- Remove unused applications, plugins, and inactive web services.

Permanent Remediation

Infrastructure Security

- Establish a formal vulnerability management and patch management program.
- Upgrade and maintain Apache, WordPress, PHP, OpenResty, and all supporting software components.
- Conduct periodic vulnerability scanning and configuration reviews.
- Deploy a Web Application Firewall (WAF) to protect public-facing applications.
- Implement network segmentation for critical university systems.

Authentication & Access Control

- Enforce Multi-Factor Authentication (MFA) for administrative and staff accounts.
- Implement Role-Based Access Control (RBAC) across university systems.
- Regularly review user privileges and inactive accounts.
- Deploy centralized identity and access management controls where feasible.

Document & Data Protection

- Implement access controls for sensitive documents and administrative resources.
- Establish secure document management procedures.
- Classify institutional data according to sensitivity levels.
- Encrypt sensitive data during transmission and storage.

Email Security

- Implement SPF, DKIM, and DMARC email authentication standards.
- Monitor email spoofing attempts and suspicious email activities.
- Conduct periodic phishing awareness training for staff and students.

Application Security

- Perform regular security assessments of WordPress applications and plugins.
- Conduct secure code reviews for custom-developed university applications.
- Implement input validation and output encoding controls to reduce injection and XSS risks.
- Establish a secure software update and testing process.

Security Monitoring

- Deploy centralized logging and security monitoring solutions.
- Enable audit logging for critical university systems.
- Implement alerting mechanisms for suspicious authentication activities.
- Establish an incident response procedure for cybersecurity events.

Verification Strategy

- Re-run Google dorking exercises to verify that unnecessary document exposure has been reduced.
- Validate implementation of SPF, DKIM, and DMARC records.
- Test authentication controls including rate limiting, password policies, and MFA enforcement.
- Confirm WordPress, PHP, Apache, and OpenResty updates have been successfully applied.
- Perform vulnerability scans against public-facing systems and portals.
- Review access permissions for document repositories and administrative interfaces.
- Verify HTTPS enforcement across all university web assets and subdomains.
- Conduct periodic penetration testing and security posture assessments.

This remediation plan prioritizes reducing exposure from public-facing systems, strengthening authentication security, improving email protection, and establishing a sustainable cybersecurity management process for KSUSTA's academic and administrative infrastructure.

13.2 SECTOR – HEALTHCARE – Kebbi State, Nigeria

Organization Name: Federal Medical Centre Birnin Kebbi (FMCBK)

Domain: fmcbirninkebbi.gov.ng

Sector: Healthcare

1. Organization Profile & Reconnaissance (OSINT) - FMCBK

1. Organization Profile & Reconnaissance (OSINT)

Organization Overview

Federal Medical Centre Birnin Kebbi (FMCBK) is a tertiary healthcare institution located in Birnin Kebbi, Kebbi State, Nigeria. The organization provides medical, diagnostic, emergency, specialist, and public healthcare services to patients across the region through its online presence and hospital management systems.

Domain Registration Information

Item	Observation
------	-------------

Domain	fmcbirninkebbi.gov.ng
Creation Date	24 February 2020
Last Updated	04 April 2022
Registrar	NITDA Hostmaster
Status	Active
Nameservers	nsa.whogohost.com, nsb.whogohost.com

The domain is actively registered and publicly accessible.

Hosting & Infrastructure Enumeration

Component	Observation
Public IP Address	131.153.147.98
Hosting Country	United States
Hosting Provider	CWIE Holdings Company / Secured Servers LLC
Reverse DNS	wghp5.wghservers.com
DNSSEC	Enabled

The organization's web infrastructure is hosted externally and accessible through a publicly routable IP address.

Web Technology Fingerprinting

Technology fingerprinting identified the following components:

Category	Technology
Web Server	Apache HTTP Server
Framework	CodeIgniter
Programming Language	PHP 7.2.34

Front-End Libraries	jQuery 3.2.1, Bootstrap, Popper.js
Fonts & UI Components	Font Awesome, Google Fonts, Ionicons
CAPTCHA Protection	Google reCAPTCHA
SSL Certificate	Let's Encrypt

The application appears to be built using the CodeIgniter PHP framework and legacy PHP 7.2.x technology stack.

Publicly Accessible Resources Identified

Google search indexing revealed multiple publicly accessible pages and services, including:

Administrative and Information Pages

- Home Page
- About Us
- Contact Us
- Medical Director Profile
- Hospital Management Information
- Departmental Content Pages
- News and Announcements
- Donation Portal
- SERVICOM Unit

Public Services

- Appointment Booking Portal
- Patient Information Pages
- Medical Publications and Books Section

Authentication Portals Discovered

The following authentication interfaces were publicly accessible:

Portal	Purpose
/login	User Authentication Portal
/mypayslips	Payslip Management System
/home/appointment	Patient Appointment System

The presence of multiple login interfaces increases the external attack surface and should be included in security monitoring activities.

Email Addresses Discovered

Publicly indexed email addresses include:

- md@fmcbirninkebbi.gov.ng
- info@fmcbirninkebbi.gov.ng

These addresses are publicly visible across multiple pages and may be leveraged by attackers for phishing, impersonation, or social engineering activities.

Search Engine Exposure (Google Dorking Results)

Passive search engine reconnaissance identified the following publicly indexed content:

Patient-Related Content

Google indexing revealed pages referencing patient information and patient management functions, including:

- Patient details pages
- Patient appointment services
- Patient account functionality
- Donation pages containing patient-related information fields

Medical Records References

Publicly accessible content references:

- Medical records systems
- Patient verification systems

- Data capture software
- Hospital management platforms

No sensitive patient records or confidential medical information were directly exposed during passive reconnaissance.

Email Security Assessment

SPF

SPF record detected and configured.

DMARC

No DMARC record identified during reconnaissance.

The absence of DMARC may increase susceptibility to email spoofing and phishing attacks targeting staff, patients, and external stakeholders.

Reconnaissance Summary

The OSINT assessment identified a publicly accessible healthcare web application supported by a CodeIgniter/PHP infrastructure. Multiple authentication portals, staff email addresses, patient-facing services, and hospital management functions were discovered through passive reconnaissance techniques.

No direct evidence of sensitive patient data exposure was observed during the reconnaissance phase. However, the presence of publicly indexed authentication portals, patient-related functionality, and missing DMARC protection contributes to the organization's external attack surface and provides useful intelligence for potential threat actors.

2. Vulnerability & Weakness Analysis – FMCBK

Vulnerability 1: Outdated PHP Runtime Environment

Observation

Technology fingerprinting identified that the Federal Medical Centre Birnin Kebbi website is running PHP 7.2.34.

Evidence

- Technology Detection: PHP 7.2.34

- Framework: CodeIgniter
- Web Server: Apache HTTP Server

Vulnerability Analysis

PHP 7.2 reached End-of-Life (EOL) and no longer receives security updates from the PHP development team.

Public vulnerability databases identify several vulnerabilities affecting PHP 7.2.x releases, including:

- CVE-2020-7069
- CVE-2020-7070

Although no exploitation was attempted during this assessment, the use of unsupported software increases the risk of exposure to publicly known vulnerabilities and future attacks.

Risk Rating: Medium

Mapping

- CWE-1104: Use of Unmaintained Third-Party Components
- OWASP Top10: 2025 - A03: Software Supply Chain Failures

Weakness 2: Public Exposure of Authentication Portals

Observation

Multiple authentication interfaces were publicly accessible through search engine indexing.

Evidence

Discovered portals include:

- /login
- /mypayslips
- /home/appointment

Weakness Analysis

Public authentication portals increase exposure to:

- Credential stuffing attacks
- Password spraying attacks
- Brute-force attempts
- Account enumeration

Healthcare organizations are frequently targeted because of the value of patient and employee information.

Risk Rating: Medium

Mapping

- CWE-306: Missing Authentication for Critical Function (Potential Risk)
- CWE-307: Improper Restriction of Excessive Authentication Attempts
- OWASP Top10 - A07:2025 – Authentication Failures

Weakness 3: Missing DMARC Email Authentication

Observation

SPF records were detected; however, no DMARC record was identified.

Evidence

Public email addresses discovered:

- md@fmcbirninkebbi.gov.ng
- info@fmcbirninkebbi.gov.ng

Weakness Analysis

Without DMARC enforcement, attackers may spoof legitimate FMCBK email addresses and conduct phishing campaigns targeting:

- Hospital staff
- Patients
- External partners
- Government agencies

Risk Rating: Medium

Mapping

- CWE-290: Authentication Bypass by Spoofing
- OWASP Top10 - A07:2025 – Authentication Failures

Weakness 4: Public Exposure of Staff Contact Information

Observation

Official email addresses are publicly indexed by search engines.

Evidence

- md@fmcbirninkebbi.gov.ng
- info@fmcbirninkebbi.gov.ng

Weakness Analysis

Publicly available email addresses may be harvested by attackers for:

- Phishing campaigns

- Social engineering attacks
- Spam distribution
- Credential harvesting operations

Risk Rating: Low

Mapping

- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
- OWASP Top10 - A01:2025 – Broken Access Control

Weakness 5: Technology Fingerprinting Disclosure

Observation

Publicly accessible information revealed details about the web application's technology stack.

Evidence

- Apache HTTP Server
- CodeIgniter Framework
- PHP 7.2.34
- jQuery 3.2.1
- Bootstrap

Weakness Analysis

Technology disclosure enables attackers to perform targeted vulnerability research and identify publicly known exploits affecting the detected technologies.

Risk Rating: Low

Mapping

- CWE-200: Information Exposure
- OWASP Top10 - A02:2025 – Security Misconfiguration

Vulnerability & Weakness Summary

ID	Finding	Risk
V-01	Outdated PHP 7.2.34 Runtime	Medium
W-01	Public Authentication Portals	Medium
W-02	Missing DMARC Record	Medium
W-03	Public Staff Email Exposure	Low

Overall Assessment

The assessment identified several externally observable weaknesses that increase the attack surface of FMCBK. The most significant findings include the use of an unsupported PHP runtime environment, publicly accessible authentication portals, and the absence of DMARC email protection. While no direct compromise of patient information was observed during this assessment, the identified weaknesses could facilitate phishing attacks, credential-based attacks, and further reconnaissance activities by malicious actors.

OVERALL MAPPING

ID	Finding	CWE	OWASP Top 10:2025
V-01	Outdated PHP 7.2.34 Runtime	CWE-1104	A03:2025 – Software Supply Chain Failures
W-01	Public Authentication Portals	CWE-307	A07:2025 – Authentication Failures
W-02	Missing DMARC Record	CWE-290	A07:2025 – Authentication Failures
W-03	Public Staff Email Exposure	CWE-200	A01:2025 – Broken Access Control
W-04	Technology Fingerprinting Disclosure	CWE-200	A02:2025 – Security Misconfiguration

3. Threat Impact & Exploitability Scenario – FMCBK

Primary Risk

Publicly Accessible Authentication Systems + Email Spoofing Risk + Outdated Web Technologies

Attack Scenario

Phase 1: Reconnaissance (MITRE ATT&CK – TA0043)

An external attacker performs passive reconnaissance against FMCBK using publicly available sources.

Activities may include:

- Google dorking of the domain
- Collection of publicly exposed email addresses
- Identification of login portals
- Technology fingerprinting
- Enumeration of publicly accessible hospital services

Information discovered:

- md@fmcbirninkebbi.gov.ng
- info@fmcbirninkebbi.gov.ng

- Login portal (/login)
- Payslip portal (/mypayslips)
- Appointment portal (/home/appointment)
- PHP 7.2.34
- CodeIgniter Framework

Phase 2: Resource Development (MITRE ATT&CK – TA0042)

The attacker creates phishing infrastructure designed to impersonate FMCBK communications.

Potential actions:

- Register look-alike domains
- Create spoofed email templates
- Prepare credential harvesting pages
- Mimic hospital appointment or administrative notifications

Because DMARC protection was not identified, spoofed emails may appear more legitimate to recipients.

Phase 3: Initial Access (MITRE ATT&CK – TA0001)

The attacker distributes phishing emails to staff members using harvested contact information.

Example lures:

- Appointment notifications
- Payslip updates
- Administrative announcements
- Medical record access requests
- Internal hospital communications

Victims may unknowingly disclose credentials through fraudulent login pages.

Phase 4: Credential Access (MITRE ATT&CK – TA0006)

If phishing succeeds, the attacker obtains valid credentials belonging to hospital staff or users.

Potential methods:

- Credential harvesting
- Password spraying
- Credential stuffing against exposed login portals

Public authentication systems increase the likelihood of such attacks.

Phase 5: Account Access and Abuse (MITRE ATT&CK – TA0003)

Compromised credentials may be used to access available web applications and services.

Potential targets include:

- Staff portals
- Payslip systems
- Appointment management functions
- Administrative accounts

The level of access would depend on the privileges associated with the compromised account.

Phase 6: Impact (MITRE ATT&CK – TA0040)

Successful compromise may lead to:

- Unauthorized system access
- Service disruption
- Exposure of internal information
- Abuse of hospital resources
- Reputational damage

No evidence of actual compromise was identified during this assessment.

CVSS (Scenario-Based Assessment)

Overall Estimated Score

CVSS v3.1: 6.5 (Medium)

Justification

- Exploitation requires external interaction or credential compromise.
- Multiple publicly accessible attack vectors exist.
- Authentication portals are exposed to the Internet.
- Missing DMARC protection increases phishing risk.
- Outdated software components increase long-term security exposure.

EPSS (Exploit Prediction Scoring System)

Estimated Likelihood

Medium–High

Factors influencing likelihood include:

- Publicly accessible login portals
- Public staff email addresses
- Missing DMARC protection
- Healthcare sector targeting
- Use of unsupported software components

Healthcare institutions remain attractive targets because of the operational importance and sensitivity of healthcare data.

Business Impact Assessment

Operational Impact

- Disruption of hospital services
- Unauthorized access to administrative systems
- Increased workload for IT and security personnel
- Potential interruption of patient-facing services

Financial Impact

- Incident response and recovery costs
- System restoration expenses
- Security remediation costs
- Potential regulatory penalties

Reputational Impact

- Loss of public confidence
- Damage to institutional reputation
- Reduced trust among patients and stakeholders

Regulatory Impact

Potential implications under:

- Nigeria Data Protection Act (NDPA)
- National Health Information Management requirements
- Government information security policies

Threat Impact Summary

The assessment identified a realistic attack path in which a threat actor could leverage publicly available information, exposed authentication portals, and weaknesses in email authentication controls to conduct phishing and credential-based attacks against FMCBK. While no evidence of active exploitation or patient data exposure was identified, the combination of outdated software, publicly exposed contact information, and missing DMARC protection increases the organization's overall attack surface and susceptibility to targeted cyber threats.

4. Mitigation & Technical Remediation Plan – FMCBK

Immediate Mitigation

- Restrict public exposure of authentication portals (/login, /mypayslips, /home/appointment) by enforcing access controls, IP restrictions, or VPN-based access where applicable.
- Implement login rate limiting, CAPTCHA enforcement, and account lockout policies to reduce brute-force and credential stuffing risks.
- Enforce strong password policies across all staff and patient-facing authentication systems.
- Enable HTTPS-only enforcement across all FMCBK web services and redirect all HTTP traffic to secure channels.
- Review and remove unnecessary public indexing of sensitive pages through robots.txt and meta-noindex configurations where appropriate.
- Configure and validate SPF, DKIM, and immediately deploy a DMARC policy (start with “p=none” for monitoring, then move to “quarantine” or “reject”).
- Conduct immediate review of all publicly exposed email addresses and reduce visibility where operationally feasible (e.g., contact forms instead of direct emails).
- Disable or restrict version disclosure headers (Apache/PHP/framework) to reduce technology fingerprinting exposure.
- Identify and remove unused endpoints, legacy modules, and inactive services within the CodeIgniter application.

Permanent Remediation

Infrastructure Security

- Establish a formal vulnerability management lifecycle covering continuous scanning, patching, and remediation tracking.
- Upgrade PHP from 7.2.34 to a supported version (PHP 8.x recommended) and migrate CodeIgniter to a maintained version.
- Implement a structured patch management policy for Apache HTTP Server, frontend libraries, and third-party dependencies.
- Deploy a Web Application Firewall (WAF) to protect against injection attacks, brute force attempts, and

automated exploitation.

- Implement network segmentation to isolate public-facing web applications from internal hospital systems.
- Harden server configuration using CIS benchmarks for Linux/Apache environments.

Authentication & Access Control

- Enforce Multi-Factor Authentication (MFA) for all administrative, staff, and privileged accounts.
- Implement Role-Based Access Control (RBAC) to ensure least privilege access across all systems.
- Introduce centralized identity management (IAM) for unified authentication across hospital platforms.
- Conduct periodic access reviews to remove inactive, redundant, or unnecessary user accounts.
- Strengthen session management controls (secure cookies, session timeout, token invalidation).

Email Security

- Fully implement SPF, DKIM, and enforce DMARC policy at “reject” level after monitoring phase.
- Deploy email gateway filtering to detect spoofed FMCBK domains and phishing attempts.
- Monitor email authentication reports (DMARC aggregate reports) for abuse patterns.
- Conduct regular phishing simulation and cybersecurity awareness training for staff.
- Implement domain monitoring to detect look-alike or impersonation domains.

Application Security

- Conduct secure code reviews for all CodeIgniter modules and custom PHP components.
- Apply secure coding practices including input validation, output encoding, and parameterized queries to prevent injection attacks.
- Remove or secure debug modes and development endpoints in production environments.
- Perform regular vulnerability assessments and penetration testing on all public-facing applications.
- Implement secure API authentication mechanisms for any backend services.

Data Protection & Privacy

- Apply data classification policies for patient, staff, and administrative data.
- Encrypt sensitive data at rest and in transit using modern cryptographic standards (TLS 1.2+ / 1.3).
- Restrict access to patient-related information through strict authorization controls.
- Implement secure logging practices while avoiding exposure of sensitive personal or medical data in logs.
- Establish data retention and disposal policies aligned with healthcare regulatory requirements.

Security Monitoring & Incident Response

- Deploy centralized logging and Security Information and Event Management (SIEM) solution.
- Enable real-time alerting for suspicious authentication attempts and abnormal login patterns.
- Maintain audit logs for all administrative and patient data access activities.
- Establish a formal incident response plan covering phishing, credential compromise, and system breach scenarios.
- Conduct periodic threat hunting and security posture reviews.

Verification Strategy

- Re-run OSINT and Google dorking exercises to confirm reduction in exposed endpoints and indexed sensitive pages.
- Validate successful implementation of SPF, DKIM, and DMARC enforcement using external email testing tools.
- Perform authentication security testing including brute-force resistance, rate limiting, and MFA enforcement checks.
- Confirm upgrade of PHP, CodeIgniter, Apache, and all third-party libraries to supported versions.
- Conduct vulnerability scanning of all public-facing systems to verify remediation of identified weaknesses.
- Review WAF logs to ensure detection and blocking of malicious traffic patterns.
- Verify HTTPS enforcement and TLS configuration compliance across all subdomains and services.
- Carry out periodic penetration testing and continuous security assessments to ensure long-term resilience.

14. TARABA STATE ASSESSMENT

14.1 SECTOR – EDUCATION – Taraba State, Nigeria

Organization Name: Federal University Wukari (FUWUKARI)

Domain: fuwukari.edu.ng

Sector: Education

1. Organization Profile & Reconnaissance (OSINT) - (FUWUKARI)

Organization Overview

Federal University Wukari (FUWUKARI) is a federal higher education institution located in Wukari, Taraba State, Nigeria. The university provides undergraduate and postgraduate education, research services, student administration, staff management, admissions processing, and academic support services.

The institution maintains a public web presence through its official website which serves as a portal for admissions, academics, research activities, staff information, student services, and institutional announcements.

Domain Registration Information

Item	Observation
Domain	fuwukari.edu.ng
Domain Status	Active
Sector	Education
Organization Type	Federal University
Country	Nigeria
Accessibility	Publicly Accessible

The domain is publicly accessible and serves as the primary online presence of the university.

Hosting & Infrastructure Enumeration

Infrastructure reconnaissance identified publicly reachable web infrastructure supporting the university website.

Component	Observation
Website	fuwukari.edu.ng
Protocol	HTTPS Enabled
Public Accessibility	Internet Accessible
DNS Resolution	Successful
Web Services	Active

The website is accessible over the public Internet and exposes multiple educational and administrative services.

Web Technology Fingerprinting

Technology fingerprinting and website enumeration identified the following technologies:

Category	Technology Identified
Content Management System	WordPress
Web Server	Apache HTTP Server
Programming Language	PHP
Front-End Frameworks	Bootstrap
JavaScript Libraries	jQuery
SSL/TLS	HTTPS Enabled
CMS Components	WordPress Themes and Plugins

The university website appears to be built using the WordPress Content Management System supported by PHP and Apache technologies.

Publicly Accessible Resources Identified

Google search indexing revealed multiple publicly accessible pages and university services.

Academic Services

- Undergraduate Admission Portal
- Postgraduate Admission Portal
- Academic Departments
- Faculties
- Research Centres
- Academic Calendar
- Student Handbook

Administrative Services

- Registry
- Bursary
- Student Affairs
- ICT Unit
- Directorates and Units
- Procurement Unit

Public Information Pages

- Home Page
- Contact Information
- News and Announcements
- Staff Information
- Departmental Profiles
- Research Activities

Publicly Indexed Student Services

Search engine reconnaissance identified references to:

- Student Affairs
- Student Handbook

- Academic Support Services
- Registration Information
- Admission Processing
- Student Welfare Services
- Remedial Programme Portal

These services are publicly discoverable through search engine indexing.

Publicly Accessible Staff Information

Search engine indexing revealed staff-related information including:

- Faculty leadership profiles
- Departmental leadership information
- Academic staff references
- Administrative office information
- Directorate contact details

Examples identified include:

- Faculty Dean profiles
- Department Heads
- Administrative Units
- Registry Contacts

Publicly Accessible Contact Information

The university publishes several contact channels.

Examples discovered include:

- info@fuwukari.edu.ng
- admissions@fuwukari.edu.ng
- registrar@fuwukari.edu.ng
- spgs@fuwukari.edu.ng

- entrepreneurship@fuwukari.edu.ng
- biotechresearch@fuwukari.edu.ng

Public telephone contact numbers are also displayed across multiple university pages.

Search Engine Exposure (Google Dorking Results)

Passive reconnaissance through Google dorking identified several categories of indexed content.

Admission Services

Indexed pages include:

- Undergraduate admissions
- Postgraduate admissions
- Admission requirements
- Application guidance
- Registration announcements

Staff Information

Indexed content includes:

- Staff directories
- Departmental leadership
- Faculty administration
- Academic personnel profiles

Student Information

Indexed references include:

- Student services
- Student welfare
- Student registration announcements
- Academic resources

PDF Documents

Google dorking using:

site:fuwukari.edu.ng filetype:pdf

identified publicly accessible PDF documents including:

- Registration notices
- Tender documents
- Procurement announcements
- Infrastructure project documents

Public Document Exposure

Publicly accessible PDF files were identified containing institutional information such as:

- Procurement activities
- Project specifications
- Registration notices
- Administrative announcements

No confidential student records, examination records, or sensitive personal data were directly exposed during passive reconnaissance.

Email Security Assessment

SPF

No publicly verified SPF information was confirmed during passive reconnaissance.

DKIM

No publicly verified DKIM information was confirmed during passive reconnaissance.

DMARC

No publicly verified DMARC information was confirmed during passive reconnaissance.

Further DNS assessment is recommended to validate email security controls.

Reconnaissance Summary

The OSINT assessment identified a publicly accessible university website providing educational, administrative, admission, research, and student-support services.

Passive reconnaissance revealed:

- Public staff information
- Multiple institutional email addresses
- Publicly indexed PDF documents
- Admission and registration services
- Student-related resources
- Departmental and faculty information
- WordPress-based web infrastructure

No direct exposure of sensitive student records, examination results, credentials, or confidential institutional information was observed during passive reconnaissance. However, the extensive public indexing of administrative resources, staff information, and downloadable documents increases the organization's external attack surface and provides useful intelligence for potential threat actors.

2. Vulnerability & Weakness Analysis – FUWUKARI

Weakness 1: Public Exposure of Administrative Documents

Observation

Multiple university PDF documents are publicly indexed and retrievable through search engines.

Evidence

Google Dork:

site:fuwukari.edu.ng filetype:pdf

Examples identified:

- Registration notices
- Procurement documents
- Tender advertisements
- Project documentation

Weakness Analysis

Public document indexing may expose organizational information useful for attacker reconnaissance including:

- Internal processes
- Procurement information
- Staff references
- Infrastructure details
- Administrative workflows

Risk Rating

Medium

Mapping

- CWE-200: Exposure of Sensitive Information
- OWASP Top 10 2025 – A01: Broken Access Control

Weakness 2: Public Exposure of Staff Contact Information

Observation

Numerous institutional email addresses are publicly accessible through search engines.

Evidence

Examples:

- info@fuwukari.edu.ng
- admissions@fuwukari.edu.ng
- registrar@fuwukari.edu.ng
- spgs@fuwukari.edu.ng

Weakness Analysis

Attackers may harvest publicly exposed emails for:

- Phishing campaigns
- Business Email Compromise (BEC)
- Social engineering

- Spam distribution

Risk Rating

Medium

Mapping

- CWE-200: Exposure of Sensitive Information
- OWASP Top 10 2025 – A01: Broken Access Control

Weakness 3: Technology Fingerprinting Disclosure

Observation

Website technologies can be identified through passive fingerprinting.

Evidence

- WordPress
- Apache HTTP Server
- PHP
- Bootstrap
- jQuery

Weakness Analysis

Technology disclosure assists attackers in identifying known vulnerabilities affecting exposed technologies.

Risk Rating

Low

Mapping

- CWE-200: Information Exposure
- OWASP Top 10 2025 – A02: Security Misconfiguration

Weakness 4: Publicly Discoverable Administrative Services

Observation

Administrative and institutional services are discoverable through search engines.

Evidence

Indexed services include:

- Registry
- Student Affairs
- ICT Unit
- Bursary
- Admissions

Weakness Analysis

Public enumeration of administrative resources provides attackers with information useful for targeting specific departments during phishing or social engineering attacks.

Risk Rating

Low

Mapping

- CWE-200: Information Exposure
- OWASP Top 10 2025 – A01: Broken Access Control

Vulnerability & Weakness Summary

ID	Finding	Risk
W-01	Public Administrative Document Exposure	Medium
W-02	Public Staff Email Exposure	Medium
W-03	Technology Fingerprinting Disclosure	Low
W-04	Public Administrative Service Enumeration	Low

3. Threat Impact & Exploitability Scenario – FUWUKARI

Primary Risk

Publicly Accessible Staff Information + Email Harvesting + Administrative Document Exposure

Phase 1: Reconnaissance (MITRE ATT&CK – TA0043)

An attacker performs passive reconnaissance using:

- Google Dorking
- Search engine indexing
- Public PDF enumeration
- Staff information gathering
- Technology fingerprinting

Information collected may include:

- Staff email addresses
- Departmental contacts
- Administrative units
- Public documents
- Website technologies

Phase 2: Resource Development (MITRE ATT&CK – TA0042)

The attacker prepares:

- Phishing emails
- Spoofed university notifications
- Fake admission announcements
- Credential harvesting portals

Phase 3: Initial Access (MITRE ATT&CK – TA0001)

Targeted phishing campaigns are sent to:

- Academic staff
- Administrative staff
- Students
- Applicants

Potential lures include:

- Admission notifications
- Registration updates
- Academic announcements
- Payroll communications

Phase 4: Credential Access (MITRE ATT&CK – TA0006)

If victims interact with malicious content, attackers may obtain:

- University credentials
- Email account access
- Administrative account access

Phase 5: Impact (MITRE ATT&CK – TA0040)

Potential consequences include:

- Unauthorized access
- Service disruption
- Credential compromise
- Institutional reputation damage
- Student trust reduction

No evidence of active compromise was identified during this assessment.

CVSS Assessment

Estimated Score:

CVSS v3.1: 5.8 (Medium)

Justification

- Exploitation requires user interaction.
- Public information facilitates reconnaissance.

- Multiple staff contacts are publicly available.
- Public document exposure supports social engineering activities.

4. Mitigation & Technical Remediation Plan – FUWUKARI

Immediate Mitigation

- Review all publicly accessible PDF documents and remove unnecessary files.
- Implement document classification before publication.
- Restrict indexing of sensitive administrative documents using robots.txt and noindex directives.
- Replace direct email publication with secure contact forms where feasible.
- Review publicly exposed staff information and limit unnecessary disclosures.
- Enable security headers to reduce information disclosure.
- Remove version disclosure from Apache, PHP, and WordPress configurations.
- Monitor search engine indexing for unintended exposure.

Permanent Remediation

Infrastructure Security

- Establish a vulnerability management program.
- Maintain WordPress core updates.
- Regularly update PHP and Apache components.
- Remove unused plugins and themes.
- Deploy a Web Application Firewall (WAF).

Email Security

- Implement SPF.
- Implement DKIM.
- Implement DMARC with progressive enforcement.
- Monitor email authentication reports.

- Conduct phishing-awareness training.

Application Security

- Perform periodic vulnerability assessments.
- Conduct annual penetration testing.
- Secure WordPress administrative interfaces.
- Enforce Multi-Factor Authentication (MFA) for administrators.
- Apply least-privilege access controls.

Information Management

- Classify public and internal documents.
- Review document publication workflows.
- Remove metadata from publicly released documents.
- Implement periodic exposure reviews.

Security Monitoring

- Deploy centralized logging.
- Monitor administrative activities.
- Establish incident response procedures.
- Conduct periodic OSINT reassessments.